



File No.: EXP202201449

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On 03/11/2021, a communication from the National Commission on Markets and Competition (CNMC) was received by the AEPD, which attached the “Agreement by which the actions carried out in relation to possible fraudulent uses of the Supply Points Information System (SIPS)” approved by the Regulatory Supervision Chamber of the CNMC. The agreement communicates a possible fraudulent use of the Supply Points Information System (SIPS).

The SIPS is defined as a database of technical, consumption, and commercial information for each of the supply points connected to electricity or natural gas distributors. The structure and access to the SIPS are developed in Article 7 of Royal Decree 1435/2002, of December 27, for the electricity sector, and in Article 43 of Royal Decree 1434/2002, of December 27, for the natural gas sector. Its format is published on the CNMC's website. The information in the SIPS is asymmetric in the regulations for gas and electricity. For each supply point, both systems include, in addition to the technical data of the point, information about monthly consumption. With some differences:

- The electric SIPS contains consumption data for the last three years, while the gas SIPS contains data for the last two years;
- The gas SIPS includes the holder's data, their address, and the address of the supply point, while since 2015, the electric SIPS does not provide this data to either the CNMC or the marketers.
- Since 2018, the electric SIPS also does not facilitate the identification of the current marketer for each supply point.

The AEPD has stated regarding the nature of the data in the electric SIPS that “the Supply Points Information System incorporates personal data, since it is possible to identify the consumer to whom the information refers based on the Supply Point Code, thus linking all the content of the system to that consumer.” The CNMC, for its part, also characterizes this data as personal data.

Regarding marketers' access to the electric SIPS, Article 7.3 of Royal Decree 1435/2002 provides the following: “marketers who have submitted the communication of the start of activity and responsible declaration, are listed in the list published by the National Commission on Markets and Competition, and meet at all times the requirements necessary to carry out the activity, may access the databases of supply points of each company free of charge.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

distributor.[...] The marketers, and other parties that make use of the information contained in the supply point databases of the distribution companies, in accordance with the provisions of this regulation and Article 46.1.k) of Law 24/2013, of December 26 (RCL 2013, 1852), of the Electric Sector, must subscribe to a code of conduct and guarantee the confidentiality of the information contained therein.” Similarly, Article 43.5 of Royal Decree 1434/2002 states that “The marketers registered in the corresponding section of the Administrative Registry of Distributors, Marketers, and Direct Consumers in the Market, as well as the Supplier Change Office, in accordance with the regulatory standard of its operation, may access the supply point databases of each distribution company free of charge. Marketers that make use of the information contained in the supply point databases of the distribution companies, in accordance with the provisions of this regulation, must guarantee the confidentiality of the information contained therein.”

Royal Decree 1011/2009, of June 19, regulated the Supplier Change Office, an entity to which the distributors have since provided the information of the SIPS so that it could be made available to marketers in order to promote free competition in the sector. The CNMC assumed the functions of the

Supplier Change Office on July 1, 2014, in accordance with the provisions of the third transitional provision of Law 24/2013, of December 26, of the Electric Sector. To provide the SIPS information to marketers, the CNMC developed an application programming interface (API) that allows authorized marketers (identified through electronic certificates or using OAuth credentials) to download complete and updated information of all supply points included in the geographical scope of the marketer (as established in the activity license of each marketer). The API also allows for individual queries of a supply point included in the geographical scope of the marketer. This authenticated access mechanism allows the CNMC to monitor the agent performing the download, recording the IP address of the device from which it is performed, the type of download made (mass or individual), and the number of downloads per time period. Thus, the CNMC conducts periodic monitoring of the downloads of mass databases and of the individual queries made with the authorized credentials, but there is no control over the use of the information after the download.

The CNMC indicates in the agreement that, through the analysis of the recorded access data and the receipt of alerts from marketers and users, it has identified a set of scenarios that suggest possible fraudulent uses of the SIPS that may impact the right to personal data protection. In summary, the scenarios are as follows:

- Seven companies whose activity is the provision to their clients of software packages that integrate the SIPS data.
- Three companies whose activity is energy consulting that appear to be accessing the SIPS without having the status of authorized agents for that purpose.
- The agreement also refers to anomalous activity of marketers in their authorized access to the SIPS (by number of queries or plurality of originating IP addresses).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/81

that could indicate a commercialization of the data or a use of access credentials by third parties.

- An authorized agent who has a contracting tool in which, by indicating the address of a supply point, returns the termination of the Unified Supply Point Code (hereinafter, CUPS) and the contracted power.

After analyzing the relevance of the information provided, on 31/03/2022, the Director of the Spanish Agency for Data Protection issued an internal note in which she considered the opportunity to conduct investigations that would allow for the collection of the necessary elements of judgment to ascertain with certainty whether actions contrary to personal data protection regulations have occurred. The note adds, however, that “taking into account the broad scope of the assumptions raised by the CNMC and the need to align it with the capabilities and resources available to the AEPD, the investigation will initially focus on the first of the described scenarios, that is, the existence of software providers that integrate the information from the SIPS into their packages and make it available to their clients, who may not be authorized marketers, and in particular, the case of the following non-energy marketing entity:

- TECNOLOGÍA SISTEMAS Y APLICACIONES S.L. (CIF: B83128033). This entity, which is not an energy marketer, and therefore does not have authorized access to the SIPS, offers the software “KOMMODO SIPS” through its commercial website, indicating the possibility of consulting the data of future clients from a single system and access to SIPS with all aggregated data from the main distributors.”

SECOND: In view of the facts, in the preliminary investigation phase, the Inspection Services of this Agency have become aware of the following facts that are reflected in the Preliminary Inspection Report:

The CNMC places the investigated party within the first case of possible fraudulent use of SIPS data in the following terms:

“Indications of marketing or use of SIPS data through advertisements on websites or information sent

to the CNMC, in the following entities, mostly non-energy marketers:

"(...)

3. TECNOLOGÍA SISTEMAS Y APLICACIONES S.L. (CIF: B83128033)

Through its commercial website, it offers the software "KOMMODO SIPS" indicating:

"Consult the data of your future clients from a single system. Access to SIPS with all aggregated data from the main distributors."

On the website, they indicate a series of logos corresponding to marketers that supposedly use this software under the indication "Marketers that already trust Kommodo." Among these marketers, more than twenty are identified without authorized access to the SIPS. An Excel file accompanying this letter includes a list of marketers identified by their logo published on this company's website, indicating whether or not they have authorized access to the SIPS databases.

This entity is not an energy marketer, and therefore does not have authorized access to the SIPS.

According to the information published on its website,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/81

It is a company specialized in the development of software solutions for the energy sector.

Link: <https://www.kommodo.com/es/>

For greater clarity, the exposition is divided according to the different concerned aspects.

****Current Situation of the System****

The investigated party states that "On September 1, 2022, the accredited marketers with whom a valid contract was maintained, both for the Free and Premium versions (i.e., paid) of Kommodo SIPS, were notified that TECSISA would cease providing the service as of October 1, 2022."

An email dated 01/09/2022 is incorporated into the document, which communicates that as of 01/10/2022, the service of Kommodo SIPS will no longer be provided. The email includes the following text:

"What happens now? If you had free access to the platform, as of that date you will no longer be able to access and consult the information.

If you had a premium subscription, we will contact you in the coming days to regularize your situation regarding the months of service not provided, in accordance with the terms of the contract."

****Context, Purpose, and Categories of Personal Data Subject to Processing****

The investigated party has provided the template of the service provision contract for access to the SIPS, which contains the following text:

"THEY STATE

(...)

II. TECSISA (the "SERVICE PROVIDER") has developed a software application, system, or SW ("software") for gas and electricity marketers, intended for the storage, processing, and consultation of databases of gas and electricity supply points, databases commonly known within the scope of the Spanish energy market as "Information Systems of Supply Points" ("SIPS") for gas and electricity.

(...)

IV.- The SERVICE PROVIDER can facilitate the process of loading, processing, and consulting the information contained in the SIPS published through the CNMC API via the web application "KOMMODO SIPS," with which users of the accredited marketers can perform searches and inquiries as well as apply filters and calculations of SIPS free of charge, in order to encourage the possible future contracting of a more advanced version of the same, as well as other software applications with complementary functionalities, a non-onerous nature that conditions certain terms and conditions of this Contract. It is for all these reasons that both parties have agreed to enter into this service lease contract for the STORAGE, PROCESSING, AND CONSULTATION OF DATABASES OF GAS AND ELECTRICITY SUPPLY POINTS ("SIPS"), initially IN ITS BASIC OR PROMOTIONAL VERSION, and without prejudice to its subsequent renewal to different advanced or paid plan versions, as will be

expressed later.

(...)

****STIPULATIONS****

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/81

Fifth. Technical conditions for access and provision of the Service. For the USER to access the provision of the Service, it authorizes the SERVICE PROVIDER to access the SIPS database through the CNMC API on behalf of the USER, based on the express authorization that the USER states to have from the gas and/or electricity distributors. The SERVICE PROVIDER will access the SIPS database through the CNMC API on behalf of the USER, and may not use the data for any purpose other than that stated in this Contract.

Notwithstanding the above, the investigated party states that the Kommodo SIPS system only provides access to the electrical SIPS and not to the gas SIPS:

“Tecsisa signs a service provision contract with those duly accredited electricity marketing companies that are interested in using Kommodo SIPS. Although the contract contemplates the possibility of also offering data related to gas, Kommodo SIPS has never supported such functionality and therefore does not provide gas information.”

Furthermore, the investigated party has provided the template of the Data Processing Agreement that it uses with its clients. Regarding the personal data subject to processing, it states in the recitals the following:

“3. That, for the development of the aforementioned services, the DATA PROCESSOR will require access to the personal data detailed below:

- a. Identification and contact data of clients (name, surname, corporate email).
- b. CUPS (Unified Supply Point Code).
- c. Power contracted by CUPS.
- d. Energy consumption data (reactive and active energy) by CUPS.”

In relation to the “Identification and contact data of clients (name, surname, corporate email)” referred to in the previous paragraph, the investigated party has indicated that “it refers to the data (name, surname, and email) of the corporate users of the marketer with access to the Kommodo SIPS application,” clarifying that “it does not refer to the clients of the marketer, but to the employees of the same who, for these purposes, act as clients of SIPS.”

Likewise, FORTIA - a marketer user of the Kommodo SIPS system until May 2022 - states the following regarding the personal data subject to processing:

“As for the origin of the data, as previously indicated, the data comes directly from the SIPS of the CNMC, and is not enriched or cross-referenced with new points or data sources. The added value of Kommodo SIPS is that it allows for agile filtering and searching of structural information and readings (in no case hourly or quarter-hourly) of each available supply point.”

Record of Processing Activities of the Investigated Party

The investigated party has provided the template of the Data Processing Agreement that includes as part of the contracting with clients. This agreement contains in stipulation 5.f) the following obligation for the investigated party:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/81

“f) The DATA PROCESSOR must maintain, in writing, a record of all categories of processing activities carried out on behalf of the DATA CONTROLLER.”

Furthermore, the investigated party has provided information regarding the processing “SIPS Loading

Process” that has been incorporated into its record of processing activities. This processing activity is defined as follows: “Based on the CUPS data from CNMC/Distributors, a process of canonization and information enrichment is carried out, which is made available to the users of Kommodo.” It specifies that the personal data processed are the CUPS and electricity consumption, and that the categories of processing activities involved in this activity are: collection, consultation, use, adaptation or modification, and conservation or storage. It also records the contact details of the processor and its data protection delegate, the list of data controllers for whom it acts as a processor in the context of this activity, and a general description of the security measures. In relation to the latter, the investigated party has also provided the applicability declaration and the certificate of the information security management system according to the UNE-ISO/IEC 27001:2014 standard. Finally, the record includes, without content, sections related to transfers, assignments, and sub-processors.

Operation of the Kommodo SIPS System

The service provision contract template for access to the SIPS includes the following descriptive paragraphs of the service provided:

“STIPULATIONS

First. - Object of the contract.

The USER contracts the SERVICE PROVIDER, who accepts, the electronic provision, remotely and on its own servers or those of third parties, of the service of storage, processing, and consultation of databases of gas and electricity supply points (“SIPS”), through the software application for gas and electricity marketers, in its basic version called “KOMMODO SIPS” (“the Service”).

(...)

Second. Functional scope.

The technical functionality of the application “KOMMODO SIPS” is the storage, processing, and consultation of the SIPS database, with the system initially prepared to load information from the available gas or electricity distribution companies through the CNMC API. The technical functionality of the application “KOMMODO SIPS” is generic in nature. It is intended for the storage, processing, and consultation of SIPS databases in non-customized terms for the USER.

The basic or free version of “KOMMODO SIPS” has a single user per client.

Specifically, the technical functionality that allows the application “KOMMODO SIPS” is detailed in ANNEX I of this Contract, which forms part of this for all purposes. The aforementioned functions are established for the basic or free version of the service provision contract, do not exhaust, and are distinct from the advanced versions or payment plans of this same application, as will be expressed later.

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/81

Fifth. Technical conditions for access and provision of the Service.

In order for the USER to access the provision of the Service, it authorizes the

SERVICE PROVIDER to access the SIPS database through the CNMC API on its behalf, based on the express authorization that the USER states to have from the gas and/or electricity distributors.

The SERVICE PROVIDER will access the SIPS database through the CNMC API on behalf of the USER, and may not use the data for any purpose other than that set forth in this Contract.

(...)

Seventh. Conditions for the SERVICE PROVIDER.

The SERVICE PROVIDER:

- Will provide access to a single USER, designated by the landlord, to the Service, providing the necessary addresses and procedures. In this basic version, the single USER will also be the Administrator (owner) of the service on behalf of the client.

- Will store, process, and make available to the USER for consultation the processed SIPS data, with the technical functionalities that the Service allows through the application “KOMMODO SIPS.”

- Will update the SIPS information at least monthly, unless due to force majeure it cannot meet this deadline.

(...)

ANNEX I

INITIAL TECHNICAL FUNCTIONALITY OF THE APPLICATION "KOMMODO SIPS"

Access to the application via nominal user

Consultation of the list of SIPS from the available distributors through the CNMC API

Search and refinement of results

Access to the structural information of a supply point

Access to the detailed monthly consumption of a supply point

The information available in the application is subject to the current legal regulations at all times, and may vary without prior notice.

Furthermore, the investigated party describes the operation of the Kommodo SIPS system in the following terms:

"Periodically, at least monthly, the Kommodo SIPS software downloads, through an automated process and via the CNMC API, a complete copy of the consumption information and supply points of electricity. This downloaded information is processed locally, and subsequently, the previous copy is deleted, so that no historical copies are maintained.

Since the means of the SIPS of the CNMC are used, the security measures employed are those provided by it, specifically through authentication according to the OAuth protocol (key and secret) of the relevant retailer.

(...) the system relies on the use of cloud computing technologies, using AWS as the IaaS (Infrastructure as a Service) provider for information storage. This physical storage is located in the AWS Data Centers in Ireland, a country that is part of the European Union.

The information, now stored locally, is offered through the web application Kommodo SIPS, which allows for agile filtering and searching of structural information and readings (in no case hourly or quarter-hourly) of each supply point.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/81

available. It is worth noting that consumption data with hourly or quarter-hour detail is not stored or offered as these are specific to each retailer.

(...) The entire process of loading SIPS into Kommodo SIPS is within the scope of the Information Security Management System (SGSI) implemented based on the UNE-ISO/IEC 27001:2014 standard, so the security measures implemented are verified annually and are part of a continuous improvement process that allows for effective risk management over the assets.

(...) Access to Kommodo SIPS is only permitted to users designated by those retailers with whom a corresponding service provision contract has been signed and remains in force.

This connection is made through any web browser (there are a series of recommended browsers and their versions, but the user is free to access with any compatible web browser), and the access control method is username and password. This connection is made via a secured connection (HTTPS) using cryptographic protocols currently considered secure (TLS 1.2).

(...) In the free version of Kommodo SIPS, since access is through a web browser, the user can only consult online through screens provided for this purpose.

In the premium version, the user has an API available to perform programmatic queries. This API is also secured and requires the provision of specific credentials and the activation of the API for that particular user.

Regarding the "premium" functionality, the investigated party has stated that "in no case do the data from Kommodo SIPS get enriched with personal data, so no additional data sources are consulted beyond the CNMC." They specifically express that the "premium" functionality incorporates features for: data filtering; data export; advice on optimizing contracted powers; estimation of "reactive energy";

and programmatic access (via API). Screenshots of these system features are included in the document.

In relation to access to the CNMC API for downloading, the investigated party states the following: "For purely practical reasons due to the high volume of data and since Kommodo SIPS does not store or offer hourly or quarter-hour consumption data, a single periodic download of the information from the CNMC is performed and access is provided to duly accredited retailers that are users of Kommodo SIPS.

Specifically, the certificate (key and secret) of NCE Comercializadora (Nueva Comercializadora Española S.L., with CIF: B99301822 and Agent Code ***CÓDIGO.1, whose geographical scope of action is Peninsular) is being used to obtain information from the CNMC API."

The CNMC, in the "Agreement by which actions taken regarding possible fraudulent uses of the SIPS are referred to the Spanish Data Protection Agency," cites NCE within the "third case" of possible fraudulent use of the SIPS.

In this regard, the following paragraphs are of interest:

"THIRD CASE.- There are indications of a possible use not in accordance with the purpose of the SIPS in the analysis of the data obtained from the individual queries of authorized marketers through the API, as it presents a very high number."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
9/81

high volume of inquiries, far exceeding the volume of switching operations recorded over a specific period of time, and even the number of supply points that are part of its client portfolio. It is also noteworthy the high number of different IP addresses used by some marketers.

(...)

1. NUEVA COMERCIALIZADORA ESPAÑOLA S.L (CIF: B99301822)

This electricity marketer (***CODE.2) made, during the study period, 1,321,413 inquiries from 6 different IP addresses, and its switching was for 9 supply points. In July 2021, it managed 592 electricity supply points."

The CNMC has provided the information exchanged with NCE in the context of its investigations.

Regarding the use of NCE's credentials, the CNMC made, among others, the following observations to NCE:

"Unusual activity has been detected in the number of individual inquiries made through the CNMC API, which is far from the average values recorded by marketers with their volume of switching and commercial activity related to the SIPS. Specifically, during the year 2021, 3,037,402 individual inquiries about consumption and 219,717 individual inquiries about supply points have been recorded from different IP addresses.

Taking a more concrete example from the records of inquiries to the SIPS database using the certificate or access credentials granted to the marketer, on February 23, 2022, 9,073 requests were recorded, mostly for information about supply points, from the IP address ***IP.1 via a machine hosted on the domain ***URL.1.

Similarly, accesses have been recorded from the IP address ***IP.2 via a machine hosted on the domain ***URL.2, from the IP addresses ***IP.3 and ***IP.4 via a machine hosted on the domain ***URL.3, and from the IP address ***IP.5 via a machine hosted on the domain ***URL.4.

At the same time, it is verified that, in addition to making an unusual number of inquiries, they download the complete files with all the information on consumption and supply points in the peninsular area."

NCE has confirmed that it has signed a contract with the investigated party, which it has attached to its submission and which corresponds to the standard contract provided by the investigated party.

Regarding the geographical scope of the marketers that are clients of Kommodo SIPS, the investigated party states that "a marketer that does not have at least a peninsular (P) scope of action will not have access to Kommodo SIPS, and this is part of the manual verification process" carried out

by the investigated party. Thus, the investigated party attaches an annex that includes the list of marketers registered in Kommodo SIPS as of 30/09/2022, reflecting that, at a minimum, their scope of action is peninsular.

The CNMC and the authorization to access the SIPS

The CNMC has stated that according to “the provisions of article 3.s) of Royal Decree 1011/2009, and in article 7.3) of Royal Decree 1435/2002, the CNMC must provide the SIPS databases to energy marketing entities.” It also expresses that for the exercise of marketing activity, interested parties must communicate the start of the activity specifying the territorial scope to the General Directorate of Energy Policy and Mines of the Ministry of Energy, Tourism and Agenda.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

10/81

Digital. It also indicates that such communication must be accompanied by a responsible declaration of compliance with the requirements for the exercise of the activity that are established. It adds that the General Directorate of Energy Policy and Mines forwards the communication made by the interested party to the National Commission of Markets and Competition (CNMC), which publishes it on its website and maintains an updated list of all marketers with a frequency of at least monthly.

Additionally, the CNMC has listed the obligations that marketers must comply with regarding the confidentiality of information related to supply points, referring to Article 46.1.k) of Law 24/2013, Article 7.3) of Royal Decree 1435/2002, and Article 43 of Royal Decree 1434/2002. It indicates that “according to current regulations, SIPS data is confidential, so the CNMC grants access to the SIPS only to electric and gas marketers who request it, all in the exercise of the powers attributed to it by virtue of its sectoral laws.”

In relation to this process of requesting access to the SIPS, the CNMC explains it as follows:

“To consult or download information from the SIPS, marketers must first request registration in the management system of the electricity and gas supply point databases from the CNMC, through the procedure established for this purpose. This request must be analyzed and validated by the CNMC before access is provided.

The registration request must be made by a legal representative of the marketer, who expressly guarantees that they will comply with the applicable regulations on the protection of personal data regarding the data received, and that they will maintain the confidentiality of the information at all times, adopting the necessary and appropriate measures in the processing processes, which are their sole responsibility. In particular, through their request, the legal representative commits to inform the personnel who use the information of its confidential nature, and its subjection to personal data protection regulations, as well as to immediately put in place the necessary means to ensure compliance with such conditions.

If there has been a change in the marketer that affects the person responsible for downloading the SIPS from the CNMC, the CNMC must be informed, as access authorization to the SIPS is nominative and is granted to a requester with power acting on behalf of and representing the requesting marketer, assuming responsibility for the use of the downloaded data.”

Furthermore, the CNMC refers to its electronic headquarters where the following is stated regarding the procedure that marketers must follow to access the SIPS:

“To consult or download, marketers must first request registration in the management system of the electricity and gas supply point databases through the procedure established for this purpose, and their request must be approved by the CNMC, which will provide access.

The registration request must be made by a legal representative of the marketer, who expressly guarantees that they will comply with the applicable regulations on the protection of personal data regarding the data received, and that they will maintain the confidentiality of the information at all times, adopting the necessary and appropriate measures in the processes of...”

C/ Jorge Juan, 6

www.aepd.es

treatment, which is their exclusive responsibility. In particular, through their application, the legal representative commits to informing the personnel who use the information of its confidential nature, and its compliance with personal data protection regulations, as well as to immediately implement the necessary means to ensure respect for such conditions.”

The electronic headquarters of the CNMC also provides instructions on how to carry out the procedure, including a section on “instructions” and another on “required documentation.” The latter lists the following documents:

“1. Registration form for marketers indicating the authorized person for the receipt of the SIPS databases

2. Copy of the enabling power for the receipt of the SIPS Databases”

The application form mentioned in the previous paragraph includes the following clauses:

“COMMUNICATION TO THE NATIONAL COMMISSION OF MARKETS AND COMPETITION
APPLICATION FOR REGISTRATION OF MARKETERS IN THE DATABASE MANAGEMENT
SYSTEM OF SUPPLY POINTS (SIPS V2) FOR GAS AND ELECTRICITY.

(...)

I.- That the APPLICANT, on behalf and representation of the REQUESTING entity, requests registration in the management system of the Databases of Supply Points for electricity and gas.

II.- That the National Commission of Markets and Competition, in the exercise of the powers attributed to it under Law 24/2013, of December 26, on the Electricity Sector and Article 3.s) of Royal Decree 1011/2009, of June 19, which regulates the Supplier Change Office, will communicate free of charge to the REQUESTING PARTY, through secure telematic procedures, the information related to the Databases of electrical and gas Supply Points concerning the geographical area established in the electricity and gas supply licenses of the REQUESTING PARTY.

III.- That the National Commission of Markets and Competition expressly warns the REQUESTING PARTY that it is obliged to comply with Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data (General Data Protection Regulation, GDPR) and Organic Law 3/2018, of December 5, on Personal Data Protection and guarantee of digital rights, and must process the data in accordance with the applicable regulations for the communication made and not apply or use them for a purpose other than that which justifies their transfer, without the possibility of communicating them, even for their conservation, to other persons, all of which is their sole and exclusive responsibility from the moment of delivery made.

IV.- That the APPLICANT, on behalf and representation of the REQUESTING PARTY, expressly guarantees that it will comply with the applicable regulations on personal data protection regarding the data received and that it will maintain at all times the confidentiality of the information of the data it has received, adopting, for this purpose, the necessary and appropriate measures in the processing processes, which are their exclusive responsibility. In particular, the APPLICANT,

in the name and representation of the PETITIONER, undertakes to inform the personnel who make use of the information of its confidential nature and its compliance with personal data protection regulations, as well as to immediately implement the necessary means to ensure respect for such conditions.”

Procedure for registration in

Kommodo SIPS

The investigated party has stated the following regarding the conditions that their clients must meet to

access the SIPS through their platform:

"To proceed with the registration of a marketer in Kommodo SIPS, it must meet the access requirements stipulated by law. To this end, Tecsisa requests the marketer to provide:

- SIMEL code of participant in the Electricity Market.
- AGENT code assigned by the CNMC.
- CIE code (Electricity Identification Code) assigned by AEAT.

Additionally, Tecsisa manually verifies the presence of the company (by corporate name and CIF) in the List of Electricity Marketers published by the CNMC on the website ***URL.5 and that its geographical scope of action is at least "Peninsular."

Once these checks are completed and the service provision contract is signed, Tecsisa proceeds to register the users designated by the marketer in the Kommodo SIPS application."

Likewise, the service provision contract template for access to the SIPS includes the following paragraphs:

"THEY STATE

(...)

III.- THE USER is a commercial company marketing gas and/or electricity, which requires a software application to manage the information provided by gas and/or electricity distributors to the CNMC. The distribution companies have implemented various systems to make the information contained in the SIPS databases available to the CNMC and the marketing companies. The CNMC publishes an API through which accredited marketers can consult the SIPS databases via software programs developed for this purpose.

That the marketing company is duly registered with the official Spanish bodies with the following codes:

- SIMEL code of participant in the Electricity Market: ____
- AGENT code assigned by the CNMC: ____
- CIE code (Electricity Identification Code) assigned by AEAT: ____

(...)

STIPULATIONS

(...)

Sixth. Conditions for the provision of the Service for the USER.

The USER:

- Declares and guarantees that the information provided to the SERVICE PROVIDER when requesting registration for the service and at any subsequent time is

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/81

truthful, is up to date, and has the right to use it by virtue of its status as a gas and/or electricity marketer."

Regarding whether compliance with the above requirements is a sufficient condition to access the SIPS, the CNMC has stated that "access to the information of the CNMC's SIPS is allowed for energy marketers that are registered in the list of marketers available on the CNMC website and that, furthermore, one or more representatives of these marketers have been authorized by the CNMC in the management system of the electricity and gas supply point databases, through the procedure established for this purpose."

Clients of the investigated party and analysis of their authorization to access the SIPS

Below are the results of the analysis of the client relationships of the Kommodo SIPS platform obtained from various documents and their circumstances regarding the consultation of the SIPS.

First, the CNMC communicated to the AEPD the following regarding the entities that, according to available indications, could be accessing the SIPS through the system of the investigated party:

"(...)

3. TECNOLOGÍA SISTEMAS Y APLICACIONES S.L. (CIF: B83128033)

Through its commercial website, it offers the software "KOMMODO SIPS" stating:

"Consult the data of your future clients from a single system. Access to SIPS with all aggregated data from the main distributors."

On the website, they indicate a series of logos corresponding to marketers that supposedly use this software under the indication "Marketers that already trust Kommodo." Among these marketers, more than twenty are identified without authorization to access the SIPS. An Excel file accompanying this letter includes a list of marketers identified by their logo published on this company's website, indicating whether or not they have authorized access to the SIPS databases."

The CNMC attached the list of companies that use the Kommodo SIPS software extracted from the interested party's website. For each of the companies, the CNMC specifies whether they have authorization for access to the SIPS. The list contained: 32 companies for which it expressly states that they did have authorization for access to the SIPS; 21 companies marked as unauthorized to access the SIPS; and 2 companies in a "low" status.

The investigated party stated to the CNMC that "Tecsisa acknowledges an outdated status in the logos published on the website www.kommodo.com. This is due to having been working in recent months on a new version of the website, now published at the time of sending this letter, in which all logos have been updated."

However, regarding the access provided through this system, the investigated party states that "it offers access to Kommodo SIPS to duly accredited electricity marketing companies registered with the CNMC, so that neither now nor in the past have companies that do not meet the legal conditions to be considered accredited marketers had access to Kommodo SIPS granted by Tecsisa." And in that same letter, the investigated party acknowledges, as of 22/03/2022, a total of 75 companies with access to the SIPS through the Kommodo SIPS platform.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/81

After analyzing this information, the following facts have been observed:

-

In relation to the discrepancy with the logos published on its website originally, it has been verified that only 13 of them are not included in the list of 75 entities. Furthermore, the investigated party informed the CNMC of the deregistration of 12 of those companies in the Kommodo SIPS system, with the company FUTURA ENERGIA Y GAS, S.L (B87370771) being the only one not mentioned. As has been verified, this company does not appear in the CNMC's list of electricity marketers but rather in the list of gas marketers. In this regard, the investigated party has stated that this company has not had and does not have access to Kommodo SIPS.

-

During the current proceedings, access was made to the website, verifying the logos published in the section "Our Clients." In this section, in addition to the logos of the business groups "Acciona," "Enel," and "Sacyr," logos of another 30 entities have been observed, all of which are present in the aforementioned list of 75 client entities of Kommodo SIPS provided to the CNMC.

-

Additionally, the investigated party communicated a list of entities that have been deregistered from the system. Thus, it can be inferred from this information provided by the interested party that out of the total of 75 companies listed in the EscritoCNMC#2, only 30 continue to have access to the Kommodo SIPS system.

-

It has been verified that, of these 30 companies, 26 are active in the list of electricity marketers published by the CNMC. The remaining four are:

o

VIVA LUZ SOLUCIONES, S.L. (CIF: B66823881) in a deregistered status since 18/03/2022.

Furthermore, this company is marked in the list provided by the CNMC as unauthorized to access the SIPS.

- o IBEROELECTRA 3000, S.L. (CIF: B12899589) in a deregistered status since 22/03/2022.
- o FUSIONA COMERCIALIZADORA, S.A. (CIF: A87414934) in a deregistered status since 20/04/2022.
- o COMERCIAL SUMINISTROS ELÉCTRICOS Y GAS, S.L. (CIF: B98989239) in a deregistered status since 21/04/2022.

- Likewise, among these 30 companies, there are another six that were classified as unauthorized to access the SIPS by the CNMC:

- o NOSA ENERXÍA S.C.G (CIF: F94090792)
- o SOLABRIA (CIF: F39781794)
- o MEGARA ENERGÍA S.COOP (CIF: F42212696)
- o PETRONAVARRA, S.L. (CIF: B31595523)
- o DX COMERCIALIZADORA ENERGÉTICA, S.A. (CIF: A81798480)
- o NOVALUZ ENERGÍA, S.L. (CIF: B93661726)

- The investigated party has provided a list of marketers registered in Kommodo SIPS as of 30/09/2022. From those present in this list, the following were classified as unauthorized to access the SIPS by the CNMC:

- o NOSA ENERXÍA S.C.G (CIF: F94090792)
 - o SOLABRIA (CIF: F39781794)
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/81
 - o MEGARA ENERGÍA S.COOP (CIF: F42212696)
 - o PETRONAVARRA, S.L. (CIF: B31595523)
 - o DX COMERCIALIZADORA ENERGÉTICA, S.A. (CIF: A81798480)
 - o NOVALUZ ENERGÍA, S.L. (CIF: B93661726)
 - o ELEVA 2 COMERCIALIZADORA SL (CIF: B98670763)
- Procedure for Withdrawal of Access to the System

Kommodo SIPS

Regarding the procedure for withdrawal of access to the SIPS, the service access contract template includes the following paragraphs:

“(…) STIPULATIONS

(...) Sixth. Conditions for the Provision of the Service for the USER.

The USER:

-

(...) Shall notify the SERVICE PROVIDER, in writing, within a maximum period of twenty-four (24) hours, of the moment when it ceases to operate as a marketer or the lack of any legal or regulatory condition that prevents it from accessing the information of the SIPS.

-

Shall notify the SERVICE PROVIDER, in writing, within a maximum period of twenty-four (24) hours, of the termination or extinction of the employment or contractual relationship of the User of the Service or any other cause for the cessation of the authorized status, requesting its immediate deregistration and cancellation of access keys."

Furthermore, the investigated party states that "it has an internal procedure whereby, periodically, it manually reviews the list of electricity marketers published by the CNMC

(<https://sede.cnmc.gob.es/listado/censo/2>) and when it detects that a company has been removed from that list, it proceeds to eliminate access and notify that company by email."

In relation to the deregistrations that occurred in the Kommodo SIPS system, the investigated party has listed the set of companies that have been deregistered from the system from 01/10/2021 (up to 22/09/2022). This list includes eight companies along with the dates of registration and deregistration on the platform. For these purposes, the investigated party has provided the communications sent by email to these companies in order to inform them of their deregistration from the Kommodo SIPS system. In these communications, the investigated party states that, having verified in the "reports of the CNMC" that the recipient no longer operates as an authorized marketer, it proceeds to deregister them from the Kommodo SIPS system in compliance with personal data protection regulations.

Likewise, the investigated party provided the CNMC with the list of companies that have been deregistered from the system and the informative communications regarding such deregistration.

On the other hand, the investigated party indicates that on 28/04/2022, it communicated to the companies whose contract was still in force the need to update it to comply with the General Data Protection Regulation (GDPR). In this regard, it adds that a number of marketers (43) declined to sign a new contract, leading to their deregistration from the system. The investigated party has attached a copy of the communications directed to these entities in which the deregistration from the Kommodo SIPS service is mentioned, dated 26/05/2022, due to the failure to formalize the new contract for adaptation to the GDPR before the deadline for doing so (25/05/2022). Among these entities is FORTIA ENERGÍA, S.L. This marketer, in its letter dated 19/05/2022, confirmed that it had accessed the SIPS through the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/81

Kommodo SIPS system under a contract signed with the investigated party on 15/11/2016. It has also been corroborated that the contract was not renewed after the renewal period expired in May 2022.

Responsible parties, data processors, and sub-processors

The investigated party states that "Tecsisa signs a service provision contract with those electricity marketing companies, duly accredited, that are interested in using Kommodo SIPS. (...) This service provision contract includes a Data Processing Agreement which specifies that the marketing company acts as the data controller and designates Tecsis as the data processor."

Regarding this matter, the tenth clause of the template service provision contract for access to the SIPS contains the following:

"Tenth. Personal data. Given that the provision of the Service requires the handling of personal data contained in the SIPS Databases, the provisions of Article 74.1, f) and l) of Law 34/1998, on the Hydrocarbons Sector; Article 40.2.m) and Transitional

Provision Three of Law 24/2013 on the Electricity Sector; and Article 11.2, regarding the principle of legal reservation for the transfer of personal data without the consent of the data subject, as well as the provisions established by the General Data Protection Regulation 2016/679 of April 27, 2016, hereinafter GDPR, in its Articles 24 and 28, are applicable.

Based on all of the above, an annex of the Data Processing Agreement is attached with the specific stipulations regarding data processing activities.

Without prejudice to what is expressly provided in this Contract, the SERVICE PROVIDER is obliged in the provision of the Service to strictly comply with the provisions of the GDPR and its implementing regulations.

The validity of this agreement has a duration identical to that of the Contract, as it is inherent to it and forms part of it for all purposes.”

And the template of the Data Processing Agreement contains the following paragraphs regarding the roles of data controller and data processor:

“DATA PROCESSING AGREEMENT

The parties involved recognize full capacity, competence, and legitimacy to sign this agreement, and for that purpose,

STATE

1. That _____ is the DATA CONTROLLER in relation to the personal data affected by the necessary processing derived from the provision of services formalized between the parties in the contract with reference number _____.

2. That TECSISA will be considered the DATA PROCESSOR in accordance with the provisions of Article 4, section 8 of the General Data Protection Regulation and, therefore, will process the data in accordance with the documented instructions provided by the DATA CONTROLLER regarding the provision of the service detailed in the contract formalized between the parties.

(...)

4. That the parties involved have agreed to formalize this agreement to regulate the processing of personal data by the DATA PROCESSOR, subject to the following:

STIPULATIONS

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/81

FIRST. - Object

The object of this agreement is to regulate the relationship between the DATA CONTROLLER and the DATA PROCESSOR, in order to comply with the provisions established in Article 28 of the General Data Protection Regulation, 2016/679 of April 27 (hereinafter, GDPR).

SECOND. - Assignment

The delivery of data by the DATA CONTROLLER to the DATA PROCESSOR does not have the legal consideration of communication or transfer of data, but rather of simple access to the same as a necessary element for the performance of the contractually established services.

Such data will be strictly necessary for the fulfillment of the contractually established services, and no copies may be made, nor may they be transferred to another computing environment, nor may they be assigned or delivered to third parties, under any title, not even for mere preservation, except as indicated regarding the possibilities of subcontracting.

In the event that the DATA PROCESSOR, including its employees or third parties contracted by it in any way, assigns the data to another purpose, communicates it, or uses it in violation of the instructions given by the DATA CONTROLLER, the stipulations of the agreement, or the current legislation at any given time, it will also be considered responsible for the processing, being liable for any infringements it may have personally incurred.

THIRD. - Subcontracting

Regarding subcontracting, the DATA CONTROLLER authorizes the DATA PROCESSOR to subcontract with the companies specified below, the services that involve the following treatments or activities:

I. Cloud computing resource provision services (hardware, storage, networks, and telecommunications), provided by Amazon Web Services EMEA SARL, with ID B186284 in its data processing centers in Ireland, therefore there is no legal international data transfer outside the EEA. To subcontract with other companies, the DATA PROCESSOR must notify the DATA CONTROLLER in writing at least fifteen (15) days in advance, clearly and unequivocally identifying the subcontractor company and its contact details, as well as the purpose of the subcontracting, with prior written authorization from the DATA CONTROLLER being necessary to proceed with the effective subcontracting.

The aforementioned will not apply to the subcontracting of auxiliary services necessary for the normal functioning of the services of the DATA PROCESSOR.

The subcontractor, who also has the status of data processor, is equally obliged to comply with the obligations established in this document for the DATA PROCESSOR and the instructions issued by the DATA CONTROLLER.

It is the responsibility of the DATA PROCESSOR to regulate the new relationship, so that the subcontractor is subject to the same conditions (instructions, obligations, security measures...) and with the same formal requirements as the DATA PROCESSOR, regarding the proper processing of personal data and the guarantee of the rights of the affected individuals.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/81

In the event of non-compliance by the data processor, the DATA CONTROLLER will remain fully responsible to the DATA RESPONSIBLE for compliance with the obligations.

FOURTH. - Specific obligations of the DATA RESPONSIBLE

a) The DATA RESPONSIBLE must comply with Articles 12, 13, and 14 in the data collection processes, with the DATA PROCESSOR being exempt from this obligation.

b) The DATA RESPONSIBLE will provide the DATA PROCESSOR with the personal data necessary for the proper performance of the agreed services.

c) The DATA RESPONSIBLE will carry out a privacy impact assessment when the data processing activity affected by the provision of the service may pose high risks to the rights and freedoms of the data subjects. Likewise, as appropriate, it will address the provisions regarding prior consultations with the Data Protection Authority.

d) The DATA RESPONSIBLE must notify the Data Protection Authority and the data subjects, as appropriate, of any security breaches that may have occurred as a result of data processing by the DATA PROCESSOR. The notification will contain the information previously provided by the DATA PROCESSOR, with the latter committing to cooperate with the DATA RESPONSIBLE with the utmost diligence to ensure that such communication is made in a timely manner and in accordance with the requirements of the applicable regulations.

e) The DATA RESPONSIBLE will ensure compliance with the current regulations on data protection by the DATA PROCESSOR.

FIFTH. - Specific obligations of the DATA PROCESSOR

a) The DATA PROCESSOR must use the personal data subject to processing, or those collected for inclusion, solely for the purpose of this assignment. Under no circumstances may the data be used for its own purposes. Such data will be strictly necessary for the fulfillment of the services.

b) The DATA PROCESSOR must process the data in accordance with the documented instructions of the DATA RESPONSIBLE. In this regard, the decisions made by the DATA PROCESSOR must always respect the documented instructions provided by the DATA RESPONSIBLE. If the DATA

PROCESSOR believes that any of the instructions infringes the GDPR or any other data protection provisions of the Union or the Member States, it will immediately inform the DATA RESPONSIBLE.
(...)

e) If the DATA PROCESSOR must transfer personal data to a third country or to an international organization, under applicable Union or Member State law, it will inform the DATA RESPONSIBLE of that legal requirement in advance, unless such law prohibits it for important public interest reasons. Except in the case mentioned above, the DATA PROCESSOR guarantees that the personal data of the DATA RESPONSIBLE will be handled in accordance with the applicable regulations.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
19/81

PROCESSING will be hosted on servers located in Spain or in any other country of the European Union.

(...)

The DATA PROCESSOR, regardless of whether it has the authorization of the DATA CONTROLLER, must comply with the obligations referred to in the current regulations on data protection:

1) Ensure that there is an adequacy decision from the Commission regarding the country, territory, specific sector, or international organization receiving the data, and therefore, an adequate level of protection is guaranteed, or

2) Provide adequate safeguards for the processing of data as specified in Article 46 of the General Data Protection Regulation, ensuring that data subjects have enforceable rights and effective legal remedies.

The DATA PROCESSOR, prior to carrying out the international transfer of data, must provide the appropriate documentation to the DATA CONTROLLER, in order to demonstrate compliance with the obligations mentioned above.

(...)

f) The DATA PROCESSOR must maintain, in writing, a record of all categories of processing activities carried out on behalf of the DATA CONTROLLER.

(...)

i) The DATA PROCESSOR must maintain the duty of confidentiality regarding the personal data to which it has had access by virtue of this assignment, even after the purpose of the assignment has ended.

j) The DATA PROCESSOR must ensure that the individuals authorized to process personal data commit, expressly and in writing, to respect confidentiality and to comply with the corresponding and agreed security measures. To this end, it will issue any necessary warnings and sign any documents required to ensure compliance with such obligations.

(...)

l) The DATA PROCESSOR must ensure the necessary training on personal data protection for the individuals authorized to process personal data.

m) The DATA PROCESSOR must adopt the necessary technical and organizational measures to ensure the present and future security of personal data, and to prevent its alteration, loss, unauthorized processing, or access, taking into account the state of technology, the costs of implementation, and the nature, scope, context, and purposes of processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, whether arising from human action or from the physical or natural environment, in accordance with the provisions of the regulations on personal data protection.

(...)

o) The DATA PROCESSOR must notify the DATA CONTROLLER, without undue delay, and in any case before the maximum period of 48 hours, of any breaches of the security of personal data under its responsibility of which it becomes aware, along with all relevant information for the documentation and communication of the incident.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/81

This notification shall not be necessary when it is unlikely that such a security breach constitutes a risk to the rights and freedoms of natural persons.

(...)

p) The DATA PROCESSOR must support the DATA CONTROLLER in carrying out impact assessments related to data protection, when appropriate.

q) The DATA PROCESSOR must support the DATA CONTROLLER in carrying out prior consultations to the supervisory authority, when appropriate.

r) The DATA PROCESSOR must provide the DATA CONTROLLER with all necessary information to demonstrate compliance with its obligations, as well as for the audits or inspections planned by the DATA CONTROLLER or another auditor authorized by it.

s) Once the provision of the entrusted services that motivated access to the data has concluded, or the established period for processing the data on behalf of the DATA CONTROLLER has ended, the DATA PROCESSOR commits to return the data, as well as any copy, medium, or document containing any personal data subject to processing, within one week from the conclusion of the provision. However, the DATA PROCESSOR may retain a copy, with the data duly blocked, as long as liabilities may arise as a result of the provision of the service. In any case, personal data must be returned to the DATA CONTROLLER when its retention is required under Union or Member State law.”

(...)

EIGHTH. - Interpretation and applicable regulations

The interpretation of this agreement, and in matters not provided for herein, shall be carried out in accordance with the provisions of current regulations and, in particular, the GDPR and Organic Law 3/2018, on Data Protection and Guarantee of Digital Rights.”

In relation to the participation of other entities in the service that the investigated party provides to its clients through Kommodo SIPS, the investigated party states that the system “is based on the use of cloud computing technologies (hardware, storage, networks, and telecommunications) provided by Amazon Web Services EMEA SARL (AWS) in its data centers located in Ireland.”

It also attaches the Spanish translation of the customer contract with Amazon Web Services, and the Data Protection Addendum (in English). The following information is extracted from these annexes.

From the translation of the contract:

“3. Security and data protection

3.1 AWS Security.

Without limitation to the provisions of Section 10 or to its obligations contained in Section 4.2, we will implement appropriate and reasonable measures designed to help you secure Your Content against any loss, access, or accidental or unlawful disclosure.

3.2 Data protection.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
21/81

You may specify the AWS regions in which Your Content will be retained.

You agree to the retention of Your Content in the AWS regions of your choice and the transfer of Your Content to them. We will not access or use Your Content, except when necessary to maintain or provide the Offered Services, or to comply with a legal provision or court order from a governmental authority. We will not (a) disclose Your Content to any governmental authority or third party, nor (b) transfer Your Content from the AWS regions selected by you; except, in each case, when necessary to comply with a legal provision or court order from a governmental authority. Unless it violates the law or a court order from a governmental authority, we will notify you of any legal requirement or order as

mentioned in this Section 3.2. We will only use Account Information in accordance with the Privacy Notice, and you consent to such use. The Privacy Notice does not apply to Your Content.

The data protection addendum addresses, among other issues:

- The section "Data Processing" states that AWS acts as a data processor for the customer, who may be a data controller or, in turn, a data processor for another.
- The section "Customer Instructions" stipulates that AWS will process the data solely in accordance with the customer's instructions.
- The section "Confidentiality Obligations of AWS Personnel" specifies that AWS imposes contractual obligations on its employees regarding confidentiality, security, and data protection.
- The section "Security of Data Processing" includes a list of security measures that AWS implements on the data processed under the contractual relationship.
- The section "Sub-processing" indicates that AWS is authorized to use sub-processors for the provision of the service. It also states that the list of sub-processors is published online and will be updated with new sub-processors at least thirty days prior to the commencement of their service provision. It further indicates that, in the absence of opposition to the sub-processor, the customer may: terminate the contract; cease the use of the service in which that sub-processor participates; or move the data to another geographical area where that sub-processor does not operate. Finally, it refers that AWS imposes the same contractual obligations on sub-processors as stipulated in this agreement.
- The section "AWS Assistance with Data Subject Requests" includes that AWS will assist the customer in responding to requests from data subjects.
- The section "Security Incident Notification" states that AWS will notify the customer of security incidents and will take appropriate response measures. It also specifies that AWS will cooperate with the customer in the notification process to the supervisory authorities.
- The section "AWS Certifications and Audits" states that AWS will assist the customer in preparing impact assessments related to the protection of personal data.
- The section "Customer Audits" includes the possibility for the customer to request the performance of audits and inspections in accordance with the stipulations described in the agreement itself.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
22/81

- The section "Return or Deletion of Customer Data" states that, according to the contract, within 90 days after its termination, AWS will delete or return the data when the customer uses the service controls to request it.
- The section "Transfers of Personal Data" details that the customer can specify the geographical area in which their data processing will take place. It adds that, once selected, AWS will not transfer the data unless necessary to provide the service ordered by the customer or in compliance with binding regulations or orders from governmental authorities. It also states that for the transfer of data to third countries, standard contractual clauses (between the data controller and processor or between processors) or other alternative mechanisms would apply.

Additionally, the investigated party states that "operationally, the way the customer specifies to AWS the geographical area in which the data processing will take place is by indicating, through the AWS management console, the region where they wish to deploy resources, including databases. In the case of Kommodo SIPS, the chosen region is eu-west-1, which corresponds to Ireland." To this effect, they provide screenshots of the systems referring to the geographical area "eu-west-1a." On the AWS website (Diligence), the code "eu-west-1" is linked to "Europe (Ireland)."

THIRD: On 24/03/2023, the Director of the Spanish Data Protection Agency agreed to initiate sanctioning proceedings against the respondent for the alleged violations of Article 6.1 of the GDPR, classified under Article 83.5.a) of the GDPR, both for accessing the SIPS and downloading information without having the legitimacy to do so, as well as for making the obtained information available to

marketing companies, with and without authorization for access to the SIPS, and for the violation of Article 25 of the GDPR, classified under Article 83.4.a) of the GDPR.

FOURTH: Upon notification of the initiation agreement, the respondent requested on 08/05/2023 an extension of the deadline for submissions and a copy of the file; the extension was granted, and a copy was provided to them on 09/05/2023.

The respondent submitted a written statement of allegations on 26/04/2023, stating, in summary: a summary of the facts presented in the initiation agreement; reference to statements made in the documents in the file; provision of documentation to be taken into account; clarification of certain statements contained in the agreement as they were considered inaccurate; reference to how the initiation agreement begins, the existence of a service provision contract between NCE and the respondent, the alleged violations of Article 6.1 of the GDPR; that energy marketers are responsible for processing in accordance with data protection regulations and are obliged to comply with the duty of diligence in contracting; the alleged violation of Article 25 of the GDPR; the issues in the sector and the respondent's compliance with the principle of privacy by design and by default; disagreement with the presence of aggravating circumstances; means of evidence and proposal for evidence.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/81

FIFTH: On 15/09/2023, the respondent submitted a document providing the Order from the Commercial Court No. X of Madrid, which opened the liquidation phase and agreed to the dissolution of the company, whereby from that date onwards, its representation would be held by Mr. A.A.A., in the capacity of insolvency administrator, which was communicated for notification purposes.

SIXTH: On 18/09/2023, the instructor of the procedure agreed to open a period for the practice of evidence, agreeing to the following:

- To consider as reproduced for evidentiary purposes the claims filed by the claimants and their documentation, the documents obtained and generated by the Inspection Services that are part of the file.
- To consider as reproduced for evidentiary purposes the allegations to the initiation agreement presented by the respondent and the accompanying documentation.
- To consider as reproduced for evidentiary purposes the documents sent by the CNMC in relation to the companies NCE and ASIC XXI.

Regarding the evidence proposed by the respondent in their written allegations, to send a request to the CNMC in order for it to issue reports specifying the existence of complaint(s) and to provide copies of them, and on the reasons why the CNMC has not initiated a procedure against the marketer NCE, these are matters that fall exclusively within the competence of the aforementioned body and are not deemed necessary or pertinent for the resolution of the present procedure and the other issues raised - why the CNMC does not recognize the existence of data processors acting on behalf of the electricity marketers and why it does not consider that the data processing agreement constitutes a valid and legitimate instrument to carry out the download of the electric SIPS on behalf of said marketers as responsible for the processing - it is not for the CNMC to determine but for the AEPD as the competent authority to initiate and resolve the procedure and specify the alleged infringements of the regulations on the protection of personal data and their possible sanctions.

On the other hand, regarding the evidence requested from the AEPD, it is already noted in the facts of the initiation agreement of this sanctioning procedure that the Director of the Spanish Agency for Data Protection issued an internal note considering the opportunity to conduct investigations in order to gather elements of judgment that would demonstrate whether actions contrary to the regulations on personal data protection had occurred. The note adds, however, that "taking into account the broad scope of the assumptions raised by the CNMC and the need to align it with the capabilities and resources available to the AEPD, the investigation will initially focus on the first of the described scenarios, that is, the existence of software providers that integrate the information of the SIPS into their packages and make it available to their clients, who may not be authorized marketers," and in this

scenario we find ourselves (companies whose activity is to provide their clients with software packages that integrate the data of the SIPS).

- Request from the respondent: the Risk Analysis document, the Impact Assessment document, since when has the respondent been downloading data from the SIPS through the CNMC API with the agent code of New.

24/81

Spanish Marketer S.L.

Have there been downloads from the SIPS with codes from other marketers? And if so, through which company/companies and codes of the agent Technology Systems and Applications, S.L. was the download of the SIPS data carried out through the CNMC API?

- Request the CNMC to inform whether: Is it mandatory to inform the CNMC in the event of a change in the marketer that affects the person responsible for downloading the SIPS data through the CNMC API, given that the authorization for access to such information is nominative and is granted to a requester with power acting on behalf and representation of the requesting marketer, assuming responsibility for the use of the downloaded data? What are the consequences or effects of this lack of communication to the CNMC? Did the marketer New Spanish Marketer S.L., with CIF: B99301822 and Agent Code R2-478, inform the CNMC of a change in said marketer that affected the person responsible for downloading the SIPS data through the CNMC API, requesting that the download would be carried out by a representative or agent of the company Technology Systems and Applications, S.L., assuming responsibility for the use of the downloaded data, through the procedure established for this purpose? If so, the CNMC should provide the form or request approved by the CNMC granting access to the SIPS to the representative of Technology Systems and Applications, S.L. Was the CNMC informed by other marketers, communicating a change in the same that affected the person/people responsible for downloading the SIPS data through the CNMC API and that this would be carried out by a representative or agent of the company Technology Systems and Applications, S.L., assuming responsibility for the use of the downloaded data through the procedure established for this purpose? If so, the CNMC should provide the form or request approved by the CNMC granting access to the SIPS to the representative of Technology Systems and Applications, S.L.

- Request from New Spanish Marketer S.L.: To inform and provide the form or request addressed to the CNMC communicating that the person responsible for downloading the SIPS data through the CNMC API would be carried out by a representative or agent of the company Technology Systems and Applications, S.L. as a consequence of the contract formalized with the aforementioned company, assuming responsibility for the use of the downloaded data.

In light of the response provided by NCE, it was reiterated that they should provide the following evidence: Meaning of the expression N/A in the responses given to the questions posed in the requested evidence that were notified to them previously, on 19/09/2023 as noted in the acknowledgment of receipt, Who and which representative of New Spanish Marketer S.L., with CIF: B99301822 and Agent Code ***CODE.1 was responsible for downloading the SIPS data through the CNMC API assuming responsibility for the use of the downloaded data? When was it communicated to the CNMC that the representative responsible for downloading the SIPS data would be a representative of the company Technology Systems and Applications, S.L., assuming responsibility for the use of the downloaded data? From what date did this change of representative occur? Provide the form/request approved by the CNMC through which access to the SIPS was granted to the representative of New Marketer.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/81

Española S.L. was responsible for downloading the data from the SIPS through the CNMC API and the form/application approved by the CNMC through which access to the SIPS was provided to the representative of the company Tecnología Sistemas y Aplicaciones, S.L. as the new responsible party

for downloading the data from the SIPS via the CNMC API; Copy of all data processing contracts signed by Nueva Comercializadora Española S.L., with CIF: B99301822, with various individuals, companies, or entities for the use of software aimed at facilitating the management of information from the Supply Points Information System (SIPS), specifying the start and end dates. Both the respondent, the CNMC, and NCE responded to the evidence presented, the content of which is included in the file. SEVENTH: On 18/10/2023, the respondent filed an appeal against the decision of the instructor of the procedure regarding the inadmissibility of the evidence proposed by the respondent during the evidence phase. In the document dated 18/09/2023 notified to the respondent, which initiated a period for the practice of evidence, it was indicated that "Against this procedural act, no administrative appeal may be filed, without prejudice to the fact that the interested party may file the appropriate appeals against the resolution that concludes the procedure, in accordance with the provisions of Article 112.1 of the LPACAP" (the underlining corresponds to the AEPD).

EIGHTH: On 03/11/2023, a Proposal for Resolution was issued stating that the Director of the AEPD should sanction the respondent for two infringements of Article 6.1 of the GDPR (downloading the SIPS database and making the information from the SIPS database available to its clients, authorized and unauthorized marketing companies, without having the legitimacy to do so) and one infringement of Article 25 of the GDPR, classified respectively under Article 83.5.a) and 83.4.a) of the GDPR.

Notified on 06/11/2023, the aforementioned Proposal, the respondent requested a copy of the file and an extension of the deadline to submit allegations; a copy of the documents was sent, and a deadline was granted to him by a document from the instructor of the same date for an additional 3 days.

On 24/11/2023, the respondent submitted a written statement of allegations summarizing the following: background related to the facts; reference to the writings of the respondent and the documentation provided in the file; the information from the SIPS discarded by the respondent is anonymous and therefore the data protection regulations do not affect or apply to the processing carried out by the respondent; Judgment of the TG of the EU which annulled the revised decision of the SEP of 24/11/2020; the Kommodo tool is not a commercial or advertising tool but a technical resource; irregularities mentioned in the proposal despite being explained during the procedure by the respondent; the non-existence of an interested party who has been affected by the services provided by the respondent; principle of arbitrariness concerning the initiation of the sanctioning procedure as the CNMC has jurisdiction regarding the alleged non-compliance.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

26/81

requirements for downloading the SIPS database, with the AEPD not being the competent authority; absence of damages or harm as well as to the rights and freedoms of individuals; violation of the right to use relevant evidence; violation of the principle of proportionality; absence of aggravating factors, with none of those indicated in the proposed resolution being applicable; filing of the procedure.

NINTH: From the actions carried out in this procedure, the following have been established,

PROVEN FACTS

FIRST. On 03/11/2021, a communication from the National Commission of Markets and Competition (CNMC) was received by the AEPD, forwarding the "Agreement by which the Spanish Agency for Data Protection is sent the actions carried out in relation to possible fraudulent uses of the SIPS" approved by the Regulatory Supervision Room of the CNMC. Through this agreement, the possible fraudulent use of the Supply Points Information System (SIPS) by energy marketers and companies not belonging to the electricity sector is communicated.

SECOND. An Internal Note dated 31/03/2022 from the Director of the Spanish Agency for Data Protection indicates the intention to conduct investigations regarding the previous document that would allow for the collection of the necessary elements of judgment to determine whether actions contrary to personal data protection regulations have occurred. The note adds that "considering the broad scope of the assumptions raised by the CNMC and the need to align it with the capabilities and resources available to the AEPD, the investigation will initially focus on the first of the described scenarios (of the

three possible), that is, the existence of software providers that integrate SIPS information into their packages and make it available to their clients, who may not be authorized marketers, among which is the case of the entity TECNOLOGÍA SISTEMAS Y APLICACIONES S.L. with CIF: B83128033.

THIRD. It is recorded that the respondent is not an energy marketer and does not have authorized access to the SIPS by the CNMC and, through its website, offers the KOMMODO SIPS software with the possibility of consulting future client data and access to SIPS data with aggregated data from the main distributors.

FOURTH. The respondent has reiterated in writings dated 01/10/2022 and 22/03/2022 that: "Tecsis has developed a software application (Kommodo SIPS) for electricity marketers, intended for the storage, processing, and consultation of databases of electricity supply points. Tecsis signs a service provision contract with those duly accredited electricity marketing companies that are interested in using Kommodo SIPS. Although the contract contemplates the possibility of also offering data related to gas, Kommodo SIPS has never supported such functionality and therefore does not provide gas information. This service provision contract includes a Data Processing Agreement in which it is specified that the marketer acts as the data controller."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

27/81

data processing and designates the defendant as the data processor of these".

"To register a marketer in Kommodo SIPS, it must meet the access requirements stipulated by law. To this end, the defendant requests from the marketer:

- SIMEL code of participant in the Electricity Market.
- AGENT code assigned by the CNMC.
- CIE code (Electricity Identification Code) assigned by AEAT.

Additionally, the defendant manually verifies the presence of the company (by corporate name and CIF) in the List of Electricity Marketers published by the CNMC on the website ***URL.5 and that its geographic scope of action is at least "Peninsular".

And that "Access to Kommodo SIPS is only permitted to users designated by those marketers with whom the corresponding service provision contract has been signed and remains in force".

Provides Model contract for the use of the Kommodo SIPS software.

FIFTH. The defendant and each marketer, according to the sixth clause of the contract, establish that it is the responsibility of the latter to inform the defendant, within a maximum period of twenty-four hours, of the moment it ceases to operate as a marketer or the lack of any legal or regulatory condition that prevents it from accessing the information of the SIPS:

"(...)

It will notify the SERVICE PROVIDER, in writing, within a maximum period of twenty-four (24) hours, of the cessation or termination of the employment or contractual relationship of the Service User or any other cause for cessation of the authorized status, requesting its immediate deregistration and cancellation of access keys".

Although it also states that "it manually verifies the presence of the company (by corporate name and CIF) in the List of Electricity Marketers published by the CNMC on the website ***URL.6 and that its geographic scope of action is at least "Peninsular".

SIXTH. The defendant and the marketer NCE signed a contract for the provision of the basic, free version of technological services for the storage, processing, and consultation of databases of gas and electricity supply points (SIPS), formalized in Madrid on 24/05/2022, which included a Data Processing Agreement under which the defendant assumed the role of Data Processor.

SEVENTH. NCE stated in a document dated 05/08/2022 that, once the contract with the defendant was signed, it obtained access as a user to the CNMC API to carry out the following tasks:

Reading information

Training adequacy

Data processing
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

28/81

Submission of the same

And that "the user accessing SIPS is ***EMAIL.1"

EIGHTH. The defendant in a document dated 30/09/2022 stated that "Specifically, the certificate (key and secret) of NCE Comercializadora (Nueva Comercializadora Española S.L., with CIF: ... and Agent Code ***CÓDIGO.1 and whose geographic scope of action is Peninsular) is being used to obtain information from the CNMC API.

As with all accredited marketers accessing Kommodo SIPS, there is a service provision contract between Tecsis and NCE".

NINTH. The defendant in the same previous document stated that "Periodically, at least monthly, the Kommodo SIPS software downloads, through an automated process, and via the CNMC API, a complete copy of the information on electricity consumption and supply points. This downloaded information is processed locally and subsequently the previous copy is deleted, so that no historical copies are maintained".

That "Access to Kommodo SIPS is only permitted to users designated by those marketers with whom the corresponding service provision contract has been signed and remains in force.

This connection is made through any web browser (there are a series of recommended browsers and their versions, but the user is free to access with any compatible web browser) and the access control method is username and password. This connection is made via a secured connection (HTTPS) using cryptographic protocols currently considered secure (TLS 1.2), as can be seen in the following screenshot".

TENTH. The CNMC provides a list of marketers that used the Kommodo SIPS application from the defendant's website, 30 were authorized for access to the SIPS, 21 were not authorized for such access, and 2 were in a deregistered status.

ELEVENTH. The defendant in response to the CNMC provided a list of 75 electricity marketers with access to the Kommodo SIPS application and an Annex of 12 marketers that had been deregistered. The defendant communicated on 30/09/2022 a list of entities that had been deregistered from the system, from the list of 75 marketers, only 30 continued to have access to the Kommodo SIPS system; 26 were active in the CNMC marketers list and 4 were in a deregistered status.

Furthermore, from the list of 30, 6 were not authorized to access the SIPS:

SOLABRIA (ENERPLUS S. COOP) (CIF: F39781794)

MEGARA ENERGÍA, S.COOP (CIF: F42212696)

DX COMERCIALIZADORA ENERGÉTICA, S.A. (CIF: A81798480).

VIVA LUZ SOLUCIONES, S.L. (CIF: B66823881)

FUSIONA COMERCIALIZADORA, S.A. (CIF: A87414934)

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

29/81

COMERCIAL SUMINISTROS ELÉCTRICOS Y GAS, S.L. (CIF: B98989239)

The respondent has stated that "...it only offers access to Kommodo SIPS to duly accredited electricity marketing companies registered with the CNMC, so neither now nor in the past have companies that do not meet the legal conditions to be considered accredited marketers had access to Kommodo SIPS..."

TWELFTH. NCE in a letter sent to the CNMC dated 22/03/2023 indicated that:

"- NCE has never used data for any commercial campaign, neither current nor prior to the change that

annulled the availability of personal data such as name or DNI, for commercial campaigns either of its own or of third parties.

- Neither NCE nor ASIC XXI work with commercial forces (except those that are active marketers in the Spanish market) nor have they transferred data to third parties for commercial campaigns.
- Neither NCE nor ASIC XXI carry out activities related to SIPS that generate income from its use by third parties.”

And it also stated that the company “EUROPEAN STRATEGIC MANAGEMENT GROUP S.L.U. (A2U) is currently the CRM service provider for NCE. Access by NCE's sales representatives to CUPS data is done exclusively from that application.”

THIRTEENTH. The company ASIC XXI in a letter sent to the CNMC dated 23/03/2022 indicated that “it is an engineering company dedicated to BackOffice and consulting in the electricity sector that has developed an ERP (Enterprise Resource Planning) for the management of the operations of electricity marketers. ASIC XXI S.L shares a large part of its activity with NUEVA COMERCIALIZADORA ESPAÑOLA S.L. (NCE)” (the underlined part corresponds to the AEPD).

And it also stated that “As indicated in point I, ASIC XXI does not market nor has it marketed the data obtained from the SIPS of the CNMC.

The data of the agent with the right of access that is used to obtain the necessary data for the correct operation in the electricity sector of ASIC XXI is:

NUEVA COMERCIALIZADORA ESPAÑOLA S.L.

B99301822

R2-478”

FOURTEENTH. NCE, as the data controller of the contract signed with the respondent, has provided the application form for registration in the management system of Consumer and Supply Point Databases (SIPS v2) for gas and electricity and the proof of its registration with the CNMC dated 12/09/2016.

FIFTEENTH. NCE has not provided the application form for registration in the management system of Consumer and Supply Point Databases (SIPS v2) for gas and electricity in which any representative of the respondent states: “That since the service provision contract with Tecnología Sistemas y Aplicaciones S.L. is from 2015, that is, almost eight years ago, the request for change of SIPS manager has not been found.”

SIXTEENTH. FORTIA, one of the electricity marketers that signed a contract with the respondent for the use of the Kommodo SIPS application, in a letter dated 19/05/2022 states that “By virtue of the contract signed between Fortia and TECSISA on November 15, 2016, and as specified in clause ten, TECSISA acts as the data processor on behalf of the marketer and, therefore, has access to the data for the purpose of loading it, maintaining the application, developing filters and calculations, based on what is indicated in the signed contract.”

A contract signed between FORTIA and the respondent dated 15/11/2016 has been provided.

SEVENTEENTH. The Record of Processing Activities has been provided, in relation to the data processing concerning the data from the SIPS; Declaration and the certificate of compliance based on the UNE ISO/IEC 27001:2014 standard that Kommodo SIPS complies with.

EIGHTEENTH. Documents Methodology Analysis Evaluation and Treatment of Risks and a copy of the Information Security Management System Certificate of ISO/IEC 27001, issued by AENOR, have been provided.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and guarantee of digital rights (hereinafter, LOPDGD), the Director of the Spanish Data Protection

Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states that: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, by the general rules on administrative procedures."

II

Preliminary Issues

Article 4 of the GDPR, Definitions, in its paragraphs 1, 2, 7, and 8, states that:

31/81

"1) 'personal data': any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is considered to be any person whose identity can be determined, directly or indirectly, in particular by means of an identifier, such as a name, an identification number, location data, an online identifier, or one or several elements specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that person";

"2) 'processing': any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination, or any other form of making available, alignment or combination, restriction, erasure, or destruction";

"7) 'data controller' or 'controller': the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the law of the Union or of the Member States determines the purposes and means of processing, the controller or the specific criteria for its designation may be laid down by the law of the Union or of the Member States."

"8) 'data processor' or 'processor': the natural or legal person, public authority, service, or other body that processes personal data on behalf of the controller."

Article 28 of the GDPR, Processor, establishes that:

"1. When processing is to be carried out on behalf of a controller, the controller shall choose only a processor that provides sufficient guarantees to implement appropriate technical and organizational measures in such a manner that processing will meet the requirements of this Regulation and ensure the protection of the rights of the data subject.

(...)

Article 29 of the GDPR, Processing under the authority of the controller or the processor, states:

"The processor and any person acting under the authority of the controller or of the processor who has access to personal data shall only process such data on instructions from the controller, unless required to do so by Union or Member State law" (the underlining corresponds to the AEPD).

And Article 33 of the LOPDGDD, Processor, establishes that:

"1. Access by a processor to personal data that is necessary for the provision of a service to the controller shall not be considered communication of data provided that the provisions of Regulation (EU) 2016/679, this organic law, and its implementing regulations are complied with.

2. A person who, in their own name and without it being established that they act on behalf of another, establishes relationships with the data subjects shall be considered a controller and not a processor, even if there is a contract or legal act with the content set out in Article 28.3 of Regulation (EU) 2016/679. This provision shall not apply to processing carried out under public sector procurement legislation.

A person who, while acting as a processor, uses the data for their own purposes shall also be considered a controller.

3. The controller shall determine whether, upon the completion of the processor's services, the personal data should be destroyed, returned to the controller, or delivered, where applicable, to a new processor.

Destruction of the data shall not proceed when there is a legal provision requiring its retention, in which case it must be returned to the controller, who shall ensure its retention for as long as such obligation

persists.

4. The processor may retain, duly blocked, the data as long as liabilities could arise from their relationship with the controller.

5. In the public sector, the competencies of a processor may be attributed to a specific body of the General State Administration, the Administration of the autonomous communities, the entities that make up the Local Administration, or to the bodies linked or dependent on them by adopting a regulatory standard for such competencies, which must incorporate the content required by Article 28.3 of Regulation (EU) 2016/679.”

III

Applicable sectoral regulations

It is necessary to refer to the specific regulations of the electricity sector.

- Directive (EU) 2019/944 of the European Parliament and of the Council of 5/06/2019 on common rules for the internal market for electricity and amending Directive 2012/27/EU (hereinafter, Directive 2019/944), whose Article 23, “Data Management,” provides in paragraph 3 that “The processing of personal data under this Directive shall be carried out in accordance with Regulation (EU) 2016/679.”

- The CNMC approved on 17/12/2019 a Resolution “by which the new formats for the exchange of information files between distributors and marketers are approved and the Resolution of December 20, 2016, is amended.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

33/81

- Royal Decree 1074/2015, of November 27, which modifies various provisions in the electricity sector. Its Third Additional Provision grants the CNMC the authority to approve by Resolution the formats of information exchange files between electricity and natural gas distributors and marketers.

- Resolution of June 25, 2014, of the CNMC, which creates an automated file of personal data.

- Law 24/2013, of December 26, on the Electricity Sector. The Third Transitional Provision establishes that from 06/30/2014, the functions previously assigned to the Supplier Change Office (OCSUM) will be performed by the National Commission on Markets and Competition (CNMC).

- Royal Decree 1011/2009, of June 19, which regulates the Supplier Change Office, article 3.s) and the modification introduced by the Third Transitional Provision of Law 24/2013.

- Royal Decree 1435/2002, which regulates the basic conditions of contracts for the acquisition of energy and access to low voltage networks, whose article 7, “Information system of supply points,” establishes in point 1 that distribution companies must have a database on all supply points connected to their networks and to the transport networks in their area, permanently complete and updated, as well as the data that must be included, and in points 2 and 3, it provides that:

“2. Distribution companies must equip themselves with the necessary computer systems that allow for the consultation of data from the supply points register and the receipt and computer validation of requests and communications with the National Commission on Markets and Competition, consumers, and electricity marketers.

Distribution companies must ensure access to the supply points databases through telematic means. In particular, distribution companies must have the necessary means so that any marketer or the National Commission on Markets and Competition can download and process the data related to all supply points connected to the distributor's networks and to the transport networks in their area, as well as carry out a detailed selection of the supply points for which they wish to access their data, based on the different categories of data that make up the aforementioned databases.

In any case, neither marketing companies nor the National Commission on Markets and Competition may access any information that directly identifies the holder of the supply point, and in particular, the data collected in sections c), z), and aa) of section 1.

Additionally, marketing companies may not access the information in section ac), which remains accessible to the National Commission on Markets and Competition in the exercise of its functions.

C/ Jorge Juan, 6

www.aepd.es
28001 – Madrid
sedeagpd.gob.es
34/81

The distribution companies shall not impose any conditions on access to and processing of these data by the marketers or the National Commission of Markets and Competition, nor shall they require, in any case, that these provide any data as a prerequisite for access to their database, including: the Universal Supply Point Code, NIF or NIE of the holder of said supply point, or the current contract number for each specific supply point for which they wish to consult the database.

Without prejudice to the right of access to the databases through telematic means, the distribution companies must send to the National Commission of Markets and Competition, or to the marketers that request it, the data relating to each and every one of the supply points connected to their networks and to the transport networks in their area through a physical computer medium that allows for their immediate and effective availability and processing, without it being required, in any case, that the marketers or the National Commission of Markets and Competition provide any data as a prerequisite for access to their database. The distribution company must send this information within a maximum period of 15 days from the date of request by the National Commission of Markets and Competition or the marketer.

3. Both the National Commission of Markets and Competition and the marketers who have submitted the communication of the start of activity and responsible declaration, are listed in the list published by the National Commission of Markets and Competition and comply at all times with the requirements necessary to carry out the activity, may access the databases of supply points of each distribution company free of charge.

The agreement to initiate the procedure for the termination of the authorization to operate as an electricity marketer, as well as the opening of criminal proceedings related to the marketing activity, shall suspend the right to access the databases of supply points of the distribution companies, without prejudice to the necessary information to carry out the transfer of customers to the reference marketer in accordance with the legally established procedure.

The marketers, and other parties that make use of the information contained in the databases of supply points of the distribution companies, in accordance with the provisions of this regulation and Article 46.1.k) of Law 24/2013, of December 26, on the Electricity Sector, must subscribe to a code of conduct and ensure the confidentiality of the information contained therein.

The exchange of information between distributors and marketers mainly refers to the processes of changing marketers, but not only to these. There are many other processes that require standardized and agile information exchange between distributors and marketers.

IV

Allegations of the Respondent

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
35/81

1. First of all, it is necessary to refer to the issue raised by the respondent in their allegations to the Proposal for Resolution, in which they invoke the judgment of the Court of Justice of the European Union of 24/11/2023 that annulled the decision of the European Data Protection Supervisor of 24/06/2020, and argue that as a result of this, the SIPS data cannot be considered as personal data, nor even pseudonymized, but rather as anonymous data. We already pointed out that Article 4, paragraph 1 of the GDPR defines personal data as: "any information relating to an identified or identifiable natural person ('the data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification number, location data, an online identifier, or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person." In order to interpret this definition, Recital 26 of the GDPR adds that "The principles of data protection

should apply to all information concerning an identified or identifiable natural person. Pseudonymized personal data, which could be attributed to a natural person by the use of additional information, should be considered information about an identifiable natural person. To determine whether a natural person is identifiable, all means, such as singling out, that could reasonably be used by the data controller or any other person to identify the natural person directly or indirectly should be taken into account."

Thus, the concept of personal data, in accordance with the GDPR, would include the so-called "pseudonymized data." The GDPR defines in its Article 4.5 pseudonymization as "the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separate and is subject to technical and organizational measures to ensure that the personal data is not attributed to an identified or identifiable natural person."

The Article 29 Working Party (hereinafter, WP29) in its Opinion 4/2007, of June 20, (WP 136) "on the concept of personal data," which analyzes the definition of personal data in Article 2 of Directive 95/46/EC, the considerations of which are fully applicable to the interpretation of Article 4.1 of the GDPR, stated regarding the information referring to an "identifiable" natural person:

"In general terms, a natural person can be considered 'identified' when, within a group of individuals, they are 'distinguished' from all other members of the group. Consequently, a natural person is 'identifiable' when, even if they have not yet been identified, it is possible to do so (which is the meaning of the suffix 'ble'). Thus, this second alternative is, in practice, the sufficient condition to consider that the information falls within the scope of the third component."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

36/81

Identification is typically achieved through concrete data that we can call "identifiers," which have a privileged and very close relationship with a specific person. [...]

The Directive mentions these "identifiers" in the definition of "personal data" in Article 2 when it states that "any person whose identity can be determined, directly or indirectly, in particular by means of an identification number or one or several specific elements, characteristic of their physical, physiological, mental, economic, cultural, or social identity, shall be declared identifiable."

Referring to the requirement that a person be "directly or indirectly identifiable," the Opinion of the GT29 4/2007 states on page 14:

"For our part, when we talk about 'indirectly' identified or identifiable individuals, we are generally referring to the phenomenon of 'unique combinations,' whether they are small or large. In cases where, at first glance, the available identifiers do not allow for the singularization of a specific person, that person can still be 'identifiable' because that information combined with other data (whether the data controller is aware of them or not) will allow for distinguishing that person from others."

"At this point, it is worth noting that, while identification through name and surname is practically the most common, that information may not be necessary in all cases to identify a person. This can happen when other 'identifiers' are used to singularize someone. [...] Also on the Internet, traffic control tools easily identify the behavior of a machine and, therefore, that of the user behind it." (The underlining is ours)

And referring to "Means of identification," page 16, the Opinion states:

"Recital 26 of the Directive pays particular attention to the term 'identifiable' by stating that 'to determine whether a person is identifiable, one must consider the set of means that may reasonably be used by the data controller or by any other person to identify that person.' This means that the mere and hypothetical possibility of singularizing an individual is not sufficient to consider the person as 'identifiable.' If, taking into account 'the set of means that may reasonably be used by the data controller or by any other person,' that possibility does not exist or is insignificant, the person should not be considered as 'identifiable' and the information should not be classified as 'personal data.' (The underlining is ours)

Well, there is no doubt that the SIPS data identifies the holder of the supply, and therefore participates in the nature of personal data, as it uniquely, individually, and specifically identifies the users of the system, leading to the conclusion that the SIPS data are personal data.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
37/81

The AEPD, in its Report 2015/29, dated 22/05/2015, which is also referenced by the respondent, states in section IV the following:

“However, it is deemed necessary to clarify what is established in the third paragraph of Article 7.2 of Royal Decree 1435/2002, in the wording proposed by the Project submitted for report, since, as indicated, that paragraph states that ‘in any case, neither the marketing companies nor the National Commission on Markets and Competition may access personal data.’

(...)

In the present case, there is no doubt, as has already been indicated previously and as this Agency pointed out in its previous reports, that the Supply Point Information System incorporates personal data, since from the Supply Point Code it is possible to identify the consumer to whom the information refers, thus allowing the entire content of the system to be linked to that consumer.

The second paragraph of Article 7.2 of Royal Decree 1435/2002, in the wording proposed by the Project, states in its second clause that ‘the distribution companies must have the necessary means so that any marketer or the National Commission on Markets and Competition can download and proceed to process the data related to all supply points connected to the distributor's networks and to the transport networks in their area, as well as carry out a detailed selection of the supply points regarding which they wish to access their data, based on the different categories of data that make up the aforementioned databases.’

Furthermore, the fourth paragraph of the same Article 7.2 establishes that ‘Distribution companies may not impose any conditions on the access and processing of this data by marketers or the National Commission on Markets and Competition, nor require in any case that they provide any data as a prior condition for access to their database, including: the Universal Supply Point Code, CIF, NIF or NIE of the holder of said supply point or the current contract number of each specific supply point for which they wish to consult the database.’

Likewise, the fifth paragraph states that ‘Without prejudice to the right of access to the databases through telematic means, distribution companies must send to the National Commission on Markets and Competition, or to the marketers who request it, the data relating to each and every one of the supply points connected to their networks and to the transport networks in their area through a physical computer medium that allows for their immediate and effective availability and processing, without it being required, in any case, that marketers or the National Commission on Markets and Competition provide them with any data as a prior condition for access to their database. The distribution company must send this information within a maximum period of fifteen days from the date of request by the National Commission on Markets and Competition or the marketer.’

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
38/81

The first consequence of what has just been reproduced is that the personal nature of the data contained in the information provided must be reiterated, given that it could be individualized based on the identity of the holder of the line. At the same time, both regulations necessarily imply that personal data contained in the supply point databases will be provided, given the very purpose of the system. This means that the literal wording of the third paragraph of Article 7.2 in the proposed wording clashes directly with what is established in the other paragraphs of the provision and in Law 24/2013 itself. However, the provision would make sense if the intention is to exclude access by marketers and by the

National Commission on Markets and Competition to any other information that directly identifies the holder of the line. In this case, the reference to "personal data" contained in that paragraph should be replaced with "identifying data of the consumer."

It should be noted that the aforementioned Article 7 of Royal Decree 1435/2002, in its section 2, states in relation to the SIPS that "In any case, neither the marketing companies nor the National Commission on Markets and Competition may access any information that directly identifies the holder of the supply point."

Therefore, the aforementioned Royal Decree 1435/2002, and Article 7 that regulates it, considers that the data contained in the SIPS falls under the category of personal data.

Article 7, in its section 2, previously transcribed, determines that "neither the marketing companies nor the National Commission on Markets and Competition may access any information that directly identifies the holder of the supply point, and in particular, the data collected in sections c), z), and aa) of section 1. Additionally, marketing companies may not access the information in section ac), which remains accessible to the National Commission on Markets and Competition, in the exercise of its functions." That is to say, marketing companies may not access the following information from the SIPS:

c) Location of the supply point, which includes full address (type of road, name of the road, number, floor, and door). This information must always refer to the supply point and not to the location, municipality, and province of the holder of said supply point as required in letter aa) of this same article.

z) Name and surname, or in their case, corporate name and corporate form, of the holder of the supply point.

aa) Full address of the holder of the supply point. This information must always refer to the holder of the supply point and not to the location, municipality, and province of said supply point as required in letter c) of this same article.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
39/81

ac) Marketing company currently supplying

However, the above does not mean that marketing companies do not access personal data, since, as this Agency has indicated in previous resolutions, the CUPS identifies the supply point and, therefore, objectively and uniquely designates and distinguishes an electricity user, who is the holder of that supply point, from other users. In other words, the CUPS is a piece of personal data as it uniquely identifies its holder without the need for the name and surname of that individual to be known, as it is a unique identifier. The CUPS is personal data because it allows for the identification of its holder by itself, just as a DNI number or a bank account number does.

In this regard, this provision also aligns with what is established in Article 4, 1) of the GDPR when it states that any person whose identity can be determined, directly or indirectly, will be considered an identifiable natural person...

The ruling of the CJEU of October 19, 2016 (case Breyer) refers to the essential task of determining whether the possibility of combining the information held by the controller with additional information held by a third party can reasonably be used to identify the data subject. This would not occur "when the identification of the data subject is prohibited by law or is practically unfeasible, for example, because it involves an excessive effort in terms of time, costs, and human resources, such that the risk of identification is, in reality, insignificant."

Significant in this regard is the Judgment of the Court of Justice in case C-319/22 / Gesamtverband Autoteile-Handel (Access to information about vehicles), which obliges car manufacturers to make available to independent agents – including repair shops, spare parts distributors, and technical information publishers – the necessary information for the repair and maintenance of the vehicles they manufacture.

A German professional association of the independent automobile parts trade filed a lawsuit before a

German court. This court referred to the Court of Justice of the European Union to clarify, among other things, whether the vehicle identification number should be considered personal data that manufacturers are obliged to disclose.

In its response, the Court of Justice states that car manufacturers are required to provide access to all information regarding the repair and maintenance of vehicles. The Court notes that vehicle identification numbers must be included in the database.

This number, in itself, lacks personal character. However, it becomes personal data when someone who has access to it has means that allow them to identify the holder of the vehicle, provided that it concerns a natural person. In this regard, the Court of Justice points out that the holder, like the identification number, is indicated on the registration certificate. Even in those cases.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

40/81

cases in which vehicle identification numbers must be classified as personal data, the General Data Protection Regulation does not oppose automobile manufacturers being required to make them available to independent agents.

Headings 44, 45, 46, 47, 48, and 49 indicate that:

44. To address this preliminary question, it is necessary to first examine whether the VIN falls within the concept of "personal data," as defined in Article 4, point 1, of the GDPR, which defines this concept as "any information relating to an identified or identifiable natural person."

45. This definition is applicable when, due to its content, purpose, and effects, the information in question is related to a specific natural person [judgment of December 8, 2022, *Inspektor v Inspektorata kam Visshia sadeben savet* (Purposes of processing personal data — Criminal proceedings) C-180/21, EU:C:2022:967, paragraph 70]. To determine whether a natural person is identifiable, directly or indirectly, one must consider all means that may reasonably be used by the data controller, as defined in Article 4, point 7, of the GDPR, or by any other party to identify that person, without requiring that all information allowing the identification of the data subject be held by a single entity (see, in this regard, the judgment of October 19, 2016, *Breyer*, C-582/14, EU:C:2016:779, paragraphs 42 and 43).

46. As the Advocate General noted in points 34 and 39 of his conclusions, a piece of data such as the VIN — which is defined in Article 2, point 2, of Regulation No. 19/2011 as the alphanumeric code assigned to a vehicle by the manufacturer to ensure the proper identification of any vehicle and which, as such, lacks "personal" character — acquires that character for anyone who reasonably has means to associate it with a specific person. Indeed, from Annex I, point II.5, of Directive 1999/37, it follows that the VIN must appear on the vehicle registration document, along with the name and address of the holder of that document. Furthermore, under points II.5 and II.6 of that annex, a natural person may be designated in that document as the owner of the vehicle or as a person who can dispose of the vehicle with a legal status different from that of the owner.

48. In these circumstances, the VIN constitutes personal data, in the sense of Article 4, point 1, of the GDPR, of the natural person mentioned in the document itself, to the extent that anyone with access to it could have means that allow them to use it to identify the owner of the vehicle referred to or the person who may dispose of that vehicle with a legal status different from that of the owner.

49. As the Advocate General pointed out in points 34 and 41 of his conclusions, when independent agents can reasonably have means that allow them to link a VIN to an identified or identifiable natural person, a matter that must be verified by the referring court, that VIN constitutes personal data for them, in the sense of Article 4, point 1.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

41/81

of the GDPR, as well as, indirectly, for the car manufacturers that provide it, even though the VIN is not, in itself, personal data for the latter, and certainly not when the vehicle does not belong to a natural person.

Translating these considerations to the present case, it can be asserted that for the respondent and its clients, the CUPS is a piece of personal data, as it identifies a person and makes them identifiable. The purpose of the CUPS is to identify the supply point of a specific residence and thereby its owner. In this regard, Opinion 4/2007, of June 20, (WP 136) "on the concept of personal data," stated regarding information relating to an "identifiable" natural person that "a natural person can be considered 'identified' when, within a group of people, they are 'distinguished' from all other members of the group. Consequently, a natural person is 'identifiable' when, although they have not yet been identified, it is possible to do so (which is the meaning of the suffix 'ble')."

In addition to all of the above, it is not acceptable to consider that we are not dealing with personal data, as the Constitutional Court has stated in its ruling 292/2000, of November 30, that the right to data protection is a fundamental right, enshrined in Article 18.4 of the Spanish Constitution, which, unlike the right to privacy in Article 18.1 CE, with which it shares the objective of providing effective constitutional protection of personal and family privacy, seeks to guarantee that person a power of control over their personal data, over its use and destination, with the purpose of preventing its illicit trafficking and harm to the dignity and rights of the affected individual. And this power of control over one's own data would disappear for the natural persons who are the holders of an electricity supply if the CUPS number were not considered personal data, since it is possible to contract the electricity supply for a specific residence as well as to change the commercial supplier if the assigned CUPS is known, depriving its holder of their decision-making power.

In conclusion, it can be stated that the information from the SIPS to which the respondent and its clients have had access, including the CUPS data, does indeed have the nature of personal data.

2. Secondly, the respondent states that "...it only offers access to Kommodo SIPS to duly accredited electricity marketing companies registered with the CNMC, so that neither now nor in the past have companies that did not meet the legal conditions to be considered accredited marketers had access to Kommodo."

However, it should be emphasized regarding this matter that the CNMC has attached a list of entities that used the Kommodo SIPS application extracted from the respondent's website, of which 32 companies did have authorization to access the SIPS; 21 companies were not authorized to access the SIPS, and 2 companies were in a "low" status.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

42/81

The respondent also communicated a list of entities that had been removed from the system; out of the total of 75 companies listed in the document dated 22/03/2022, only 30 continued to have access to the Kommodo SIPS system. Of these 30 entities, 26 were active in the list of electricity marketers published by the CNMC; the remaining four: Viva Luz Soluciones, S.L. which was removed on 18/03/2022, were not authorized to access the SIPS; Iberoeléctrica 3000, S.L. which was removed on 22/03/2022; Fusiona Comercializadora, S.A. which was removed on 20/04/2022; and Comercial Suministros Electricos y Gas, S.L. which was removed on 21/04/2022.

Furthermore, among these 30 entities, there were another six that have been classified as unauthorized to access the SIPS by the CNMC, information that has been confirmed in evidence by the aforementioned agency: Nosa Enerxia, S.C.G Solabaria, Megara Enercia S.Coop., Petronavarra, S.L., DX Comercializadora Energética, and Novaluz Energía.

Therefore, this allegation must be dismissed.

3. Thirdly, it is appropriate to address the respondent's claim that "it does not commercialize the information contained in the SIPS of the CNMC" and that "it has not obtained any economic benefit, since these marketers had contracted the FREE (free) version of Kommodo SIPS at the time they were removed..."

However, these statements cannot be accepted as the file is filled with declarations and statements in a completely opposite sense; the respondent had developed a business model with electricity marketers, both authorized and unauthorized for access to the SIPS data by the CNMC, even when in a removed status, for its own benefit without it being recorded that it acted on behalf of another and outside the contracts signed both with NCE and with the rest of the marketers.

The respondent itself indicated in a document dated 30/09/2022 that the exploitation of the software application distinguishes two options: the free and the premium (paid) version; in its free version, since access is through a web browser, the user can only consult online through screens provided for that purpose.

In the premium version, the user has an API available to make programmatic queries. This API is also secured and requires the provision of specific credentials and the activation of the API for that specific user.

Regarding the "premium" functionality, the investigated party has stated that "in no case do the data from Kommodo SIPS get enriched with personal data, so no additional data sources to the CNMC are consulted." It specifically states that the "premium" functionality incorporates features for: data filtering; data export; advice on optimizing contracted powers; estimation of "reactive energy"; and programmatic access (via API). It includes screenshots of these system features in the document.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

43/81

And in the document dated 09/02/2023: "The standard contract document for the provision of access services to the SIPS (Annex II of the referenced document) defines, in its Annex I, the functionality offered by the Kommodo SIPS system in its basic or free version. Furthermore, it states that this functionality does not exhaust and is distinct from the advanced or paid versions."

In the same document, it notes that: "On September 1, 2022, accredited marketers with whom a valid contract was maintained, both for the Free and Premium versions (i.e., paid) of Kommodo SIPS, were notified that TECSISA would cease to provide the service as of October 1, 2022."

And in clause IV of the contract: "IV.- The SERVICE PROVIDER may facilitate the process of loading, processing, and consulting the information contained in the SIPS published through the CNMC API via the web application "KOMMODO SIPS," with which users of the accredited marketers can perform searches and inquiries as well as apply filters and calculations of SIPS free of charge, in order to encourage the possible future contracting of a more advanced version of the same, as well as other software applications with complementary functionalities, a non-onerous nature that conditions certain terms and conditions of this Contract. For all these reasons, both parties have agreed to enter into this service lease contract for the STORAGE, PROCESSING, AND CONSULTATION OF THE DATABASE OF GAS AND ELECTRICITY SUPPLY POINTS ("SIPS"), initially IN ITS BASIC OR PROMOTIONAL VERSION, and without prejudice to its subsequent renewal to different advanced or paid plan versions, as will be expressed later."

Furthermore, in the emails provided by the respondent in which it communicated that as of 01/10/2022 the service of Kommodo SIPS would cease, it was indicated:

"What happens now? If you had free access to the platform, from that date you will no longer be able to access and consult the information.

If you had a premium subscription, we will contact you in the coming days to regularize your situation regarding the months of service not provided, in accordance with the terms of the contract."

Finally, in the document dated 26/04/2023, it stated: "In fact, beyond the economic compensation received from its clients for the provision of the Kommodo SIPS service, in its Premium version..."

Therefore, once the databases were downloaded, the information contained in them was offered to the marketers, who could perform searches and inquiries, initially free of charge, although according to the respondent itself, seeking to incentivize the contracting of more advanced versions and other software applications, obviously for a fee.

The CNMC has conclusively stated that "it is not possible to commercialize the data of the SIPS of the

CNMC. It is a database owned by the CNMC, and only this body can offer access to the information it contains.”

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
44/81

4. Furthermore, the respondent has claimed that the Kommodo tool is neither a commercial nor an advertising tool but rather a technical resource for downloading and consulting the SIPS.

In relation to the aforementioned issue, no one doubts the technical nature of the mentioned application and its usefulness for marketers in processing the data contained in the SIPS and serving as a validation tool for the structural data in the switching process, but its commercial nature is also undeniable, as could not be otherwise given the activity and condition of the company, a matter that has already been raised in the previous grounds. Moreover, it suffices to point out that in Clause Eight, Expansion or reduction of service capacity, section B.2., Price of plans and their renewal, it establishes that:

“TECSISA, for the use of the CLIENTS of the ‘KOMMODO SIPS’ platform, has the right to charge the applicable rates at any given time.

The payment method of the aforementioned price by the CLIENT will be through direct debit to the account designated by the CLIENT, at the beginning of the billing period for each of the contracted payment plans.

TECSISA may claim from the client the financial expenses incurred due to the returns of receipts issued for the collection of the price of the contracted service. TECSISA may also include a surcharge in future receipts. Such surcharge will be in the concept of financial charges at a weekly interest rate of 10% calculated on the amount of the installment(s) affected by such non-payment or delay.”

5. In relation to the service contract, the statements of the respondent regarding the grounds contained in the proposal have not been refuted, adhering to and reiterating the argument that the data is anonymous and that the purposes of the processing have not been altered.

6. The respondent has expressed disagreement with the penalties indicated for the infringements committed without taking into account the bankruptcy situation and that he lacks the economic capacity to meet the payment of the stipulated penalties, considering that this constitutes a clear violation of the principle of proportionality.

Article 83.1 of the GDPR states that “Each supervisory authority shall ensure that the imposition of administrative fines in accordance with this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

The fines, as deduced from the provision, must be effective, proportionate, and dissuasive for the achievement of the intended purpose of the GDPR.

For this system to function with all its guarantees, it is necessary that several elements are deployed in an integral and complete manner. The application of rules external to the GDPR regarding the determination of fines in each of the Member States applying their national law, whether due to circumstances...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
45/81

aggravating or mitigating factors not provided for in the GDPR - or in the LOPDGDD in the Spanish case as permitted by the GDPR itself - would undermine the effectiveness of the system, losing its meaning, its teleological purpose, the will of the legislator, resulting in fines imposed for different infringements ceasing to be effective, proportionate, and deterrent. In this way, it would also deprive the interested parties of the effective guarantee of their rights and freedoms, weakening the uniform application of the GDPR. The mechanisms for protecting the rights and freedoms of citizens would be diminished, which would be contrary to the spirit of the GDPR.

The GDPR has its own principle of proportionality that must be applied in its strict terms. In Title VIII of the LOPDGDD relating to "Procedures in the event of a possible violation of data protection regulations," Article 63, which opens the Title, provides in its second paragraph that "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures." Although there is a clear reference to the LPACAP, there is absolutely no subsidiary application regarding the LRJSP, which does not contain any provision in its articles relating to any administrative procedure.

Just as the AEPD is not applying the aggravating and mitigating factors provided for in Article 29 of the LRJSP, since the GDPR establishes its own, therefore, there is no legal gap or subsidiary application of the same.

Regarding the principle of proportionality of sanctions, the National Court in numerous rulings has indicated that the principle of proportionality cannot be exempt from judicial review, as the margin of appreciation granted to the Administration in the imposition of sanctions within the legally established limits must be developed by weighing, in any case, the concurrent circumstances, in order to achieve the necessary and due proportion between the alleged facts and the responsibility required, given that every sanction must be determined in accordance with the severity of the infringement committed and according to a criterion of proportionality in relation to the circumstances of the fact. Thus, proportionality constitutes a normative principle that is imposed on the Administration and that reduces the scope of its sanctioning powers.

Well, in accordance with the circumstances present in this case, the resolution does not violate the principle of proportionality in the determination of the imposed sanctions, being weighed and proportionate to the severity of the infringement committed, the importance of the facts, as well as the circumstances taken into account to grade the sanction, without any reasons being appreciated that further justify the reduction made, especially considering the amount to which such sanctions may rise in accordance with Articles 83.5.a) and 83.4.a) of the GDPR, which provide for both very serious infringements of Article 6.1 and for the serious infringement of Article 25 of the GDPR, "... administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 4% of the total annual global turnover of the financial year."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

46/81

previously, opting for the higher amount" or "... with administrative fines of 10,000,000 EUR at most or, in the case of a company, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount," respectively.

7. The respondent has alleged a violation of the right to use relevant evidence due to the rejection of the requests for information submitted by the respondent to the CNMC and AEPD.

As already indicated to the respondent, regarding the referral to the CNMC to provide a report on the existence of complaints and copies thereof, as well as the reasons why the aforementioned body had not initiated proceedings against the marketer NCE, it was indicated that these were matters within the competence of the said body; and regarding the rest of the issues raised - Why does the CNMC not recognize the existence of data processors acting on behalf and at the request of electricity marketers? Why does it not consider that the data processing agreement constitutes a valid and legitimate instrument to carry out the discharge of the electric SIPS on behalf and at the request of such marketers as data controllers? - it was indicated that these were matters that the CNMC was not competent to determine, as they pertained to issues within the competence of the AEPD as the authorized body to rule on them, initiate and resolve, in any case, the proceedings to investigate and clarify the infringements of the regulations on personal data protection and their possible sanctions. Furthermore, regarding the evidence requested from the AEPD, reference was made to the internal note issued by the Director of the Spanish Agency for Data Protection considering the opportunity to

conduct investigations in order to gather evidence that would demonstrate whether actions contrary to personal data protection regulations had occurred; although, it was noted that “taking into account the broad scope of the issues raised by the CNMC and the need to align it with the capabilities and resources available to the AEPD, the investigation will initially focus on the first of the described scenarios, that is, the existence of software providers that integrate SIPS information into their packages and make it available to their clients, who may not be authorized marketers” and that we find ourselves in this latter scenario.

It was also indicated that the above did not prevent the respondent from alleging what they deemed appropriate and, if they considered it pertinent, to file the appropriate appeals against the resolution that concluded the proceedings.

However, the respondent, as recorded, submitted an appeal on 18/10/2023 against this decision, despite the fact that in the notification dated 18/09/2023 sent to the respondent, which initiated the evidence collection period, it was stated that “Against this procedural act, no administrative appeal may be filed, without prejudice to the fact that the interested party may file the appropriate appeals against the resolution that concludes the proceedings, in accordance with the provisions of Article 112.1 of the LPACAP.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

47/81

However, as noted in the file, this appeal was dismissed by Resolution dated 15/12/2023.

8. The respondent has alleged the arbitrariness involved in the initiation of the present sanctioning procedure, as its subject matter pertains to issues governed by the regulations applicable to the electricity sector and not, as intended by the AEPD, by the regulations on personal data protection.

However, such an argument cannot be accepted; the respondent, as outlined in the previous grounds, entered into a data processing agreement with the data controller, the company NCE, which stipulates the obligations undertaken by it.

In accordance with the provisions of Article 33 of the LOPDGDD, by acting in its own name, it becomes the data controller, a matter that has not been refuted by the respondent in its allegations.

Article 4, paragraph 1, of the GDPR considers processing to be “any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not,” and among such operations, it specifies “the collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment, combination, restriction, erasure or destruction.”

In the data processing agreement submitted to the file, it is indicated that the processor shall not be authorized to access the SIPS database unless authorized to do so by the controller, nor to transfer its data. Thus, Clause Five, Technical Conditions for Access and Provision of the Service, establishes that “For the USER to access the provision of the Service, it authorizes the SERVICE PROVIDER to access the SIPS database through the CNMC API on behalf of the USER, based on the express authorization that the USER states to have from the gas and/or electricity distributors.

The SERVICE PROVIDER will access the SIPS database through the CNMC API on behalf of the USER, and may not use the data for any purpose other than that stated in this Contract.”

The contract also includes a confidentiality clause, aimed at ensuring the security and confidentiality of the information to which the processor may have access, respecting the secrecy and confidentiality of the information to which it will have access, and may not be used for any purpose other than that for which it was contracted.

In Clause Thirteen of the contract, it is stated regarding the processed data: “Not to disclose, reveal, or transfer to any third party any data contained in the communications, documents, or instructions that may be mutually delivered for the fulfillment of this contract, using them solely for the legitimate purposes agreed upon in this document. Not to retain, copy, or reproduce...”

C/ Jorge Juan, 6

www.aepd.es

in whole or in part, the content of the data to which they have access in the legitimate compliance and execution of the contract”

Therefore, the treatments carried out by the respondent are contrary to the contract of assignment and to the regulations on the protection of personal data, affecting the principle of legitimacy established in Article 6 of the GDPR.

9. The respondent claims that it has demonstrated to the CNMC and the AEPD that it did not grant access to the information of the SIPS to marketers or other unaccredited entities.

However, such a statement has not been disproven by the respondent; during the evidentiary period, the CNMC confirmed that certain marketers listed by the respondent for access to the SIPS through the Kommodo application were not authorized for access to the aforementioned information; information that had already been corroborated by the CNMC at the request of the instructor acting in the investigation phase.

It is not true, as the respondent states, that the Proposal indicates that it made mass calls to the CNMC's API; it is true that such queries were made by NCE and ASIC XXI.

However, what the respondent cannot deny is that both the treatment carried out as a result of the downloading of the SIPS databases through the CNMC's API, downloads that were carried out monthly, and the accesses to the information contained therein by the marketers, both authorized and unauthorized by the CNMC, with which the respondent had signed assignment contracts, caused and raised an indeterminate number of queries and accesses to the aforementioned databases without any legitimacy being accredited for their execution, which constitutes a violation of the regulations on the protection of personal data.

This conduct, on the other hand, did not arise recently, but was adopted at the beginning of the respondent's activity, as evidenced by the statement contained in its written allegations to the Proposal: “since October 15, 2015, TECSISA began to provide access services to the SIPS through its Kommodo SIPS platform. This service is provided after signing a contract with the interested accredited marketers and downloading the data from the 5 main distributors (IBERDROLA DISTRIBUCION ELECTRICA, S.A., UNION FENOSA DISTRIBUCION, S.A. (Gas Natural), E.ON DISTRIBUCIÓN, S.L., HIDROCANTABRICO DISTRIBUCION ELECTRICA, S.A. and ENDESA DISTRIBUCION ELECTRICA, S.L.). After the download, the data is processed and consolidated to provide the user marketers access to it from a single application, which also provides filters and other value-added functions.”

10. The respondent also claims the non-existence of an interested party who would have been affected by the services provided by the respondent and the non-existence of damages to individuals in their rights and freedoms.

The AEPD is responsible for ensuring compliance with data protection regulations and overseeing their application. To this end, it exercises functions and powers as determined in Article 57 of the GDPR; in its paragraph 1, letters a) and h) establish that:

“1. Without prejudice to other functions under this Regulation, it shall be the responsibility of each supervisory authority, within its territory:

a) to monitor the application of this Regulation and to ensure its application;

(...)

h) to carry out investigations into the application of this Regulation, in particular based on information received from another supervisory authority or another public authority;

(...)”

It should be noted that Article 77 of the GDPR recognizes the right of any data subject to lodge a

complaint with a supervisory authority, particularly in the Member State where they have their habitual residence, place of work, or the place of the alleged infringement, if they consider that the processing of personal data concerning them infringes this Regulation. This right is also provided for in Article 52 of L.O. 7/2021.

These complaints are processed in accordance with the provisions of Article 65 of the LOPDGDD, always taking into account the general requirement that the processing that motivates the complaint relates to personal data concerning the complainant or that the complaint is made by a person (natural or legal) who has seen their own rights recognized in other specific regulations violated.

On the other hand, complaints can be processed by the AEPD, in accordance with the control functions attributed in the aforementioned Article 57.1.a), the supervisory and control functions provided for in Article 49.1 a) of L.O. 7/2021, and the supervisory functions in accordance with Article 27.2.a) of the AEPD Statute.

However, in the present case, the CNMC, a public body with its own legal personality, forwarded to the AEPD the "Agreement by which the actions carried out in relation to possible fraudulent uses of the SIPS are referred to the AEPD" and, in the exercise of its functions and powers, proceeded to conduct investigations based on the information that was transferred to it in order to determine the possible violation of the GDPR and LOPDGDD.

Therefore, nothing prevents the AEPD, as the body responsible for ensuring compliance with the GDPR, from ex officio deciding to open a sanctioning procedure in light of the investigations carried out if it finds reasonable indications that data protection regulations are being violated, even if the potential affected parties have not lodged a complaint with it.

V

Unfulfilled Obligation. Article 6

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

50/81

Firstly, two infringements of Article 6, Lawfulness of processing, of the GDPR are attributed to the respondent, which in its paragraph 1 states that:

"1. Processing shall be lawful only if at least one of the following conditions applies:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
- b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;
- c) processing is necessary for compliance with a legal obligation to which the controller is subject;
- d) processing is necessary to protect the vital interests of the data subject or of another natural person;
- e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;
- f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular when the data subject is a child.

The provision in letter f) of the first paragraph shall not apply to processing carried out by public authorities in the performance of their tasks."

Furthermore, the GDPR in its Article 5 establishes the principles that must govern the processing of personal data and, in its paragraph 1 states that:

"1. Personal data shall be:

- a) processed lawfully, fairly, and in a transparent manner in relation to the data subject (<>).
(...)"

And in its paragraph 2, it establishes that:

"2. The controller shall be responsible for compliance with the provisions of paragraph 1 and shall be

able to demonstrate compliance (<>).”

Therefore, all processing of personal data must respect the principles that govern it, as listed in Article 5.1 of the GDPR, including the principle of lawfulness which is further developed in Article 6.1 of the GDPR.

From the aforementioned article, it follows that the processing of data requires the existence of a legal basis that legitimizes it.

In accordance with this provision, in addition to consent, there are other possible bases that legitimize the processing of data without the need to have the consent of the data subject.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

51/81

authorization of its holder, in particular, when necessary for the execution of a contract in which the affected party is a party or for the application, at their request, of pre-contractual measures, or when necessary for the satisfaction of legitimate interests pursued by the data controller or by a third party, provided that such interests do not prevail over the interests or the rights and fundamental freedoms of the affected party requiring the protection of such data. The processing is also considered lawful when necessary for compliance with a legal obligation applicable to the data controller, to protect vital interests of the affected party or another natural person, or for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller.

Regarding energy marketers, both access to and processing of personal data contained in the Supply Points Information System (SIPS) find their legitimacy basis in paragraph e) of Article 6.1 of the GDPR: “(...)

e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller”

(...)

Now, as established in the regulations corresponding to the electricity sector, such authorization will only be valid if a series of requirements are met beforehand.

It should be noted that this procedure arises from the letter dated 03/11/2021 from the CNMC, forwarding to the AEPD the “Agreement by which the Spanish Agency for Data Protection is informed of the actions taken regarding possible fraudulent uses of the SIPS” approved by the Regulatory Supervision Chamber of the CNMC, which suggested a possible fraudulent use of the Supply Points Information System (SIPS).

The CNMC indicated that, through the analysis of recorded access data and the receipt of notices from marketers and users, scenarios suggesting possible fraudulent uses of the SIPS had been identified that could impact the right to the protection of personal data. In summary, the scenarios are as follows: Once the information provided was analyzed, the opportunity to conduct investigations that would allow for the collection of the necessary elements of judgment to ascertain with certainty whether actions contrary to personal data protection regulations had occurred was considered, and taking into account the assumptions raised with the AEPD's own capabilities and resources, the investigations have focused on the first of the described scenarios, namely, the existence of software providers that integrate SIPS information into their packages and make it available to their clients, particularly the claimant who is not an energy marketer and therefore does not have authorized access to the SIPS and who, through their website, offered the software “KOMMODO SIPS” indicating the possibility of

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

52/81

consultation of future clients' data from a single system and access to SIPS with all aggregated data from the main distributors.

Therefore, regarding the claim, the facts revealed demonstrate that the entity, which is not an energy

marketer, integrates information related to the SIPS into its systems for its own purposes and makes it available to its clients, both authorized and unauthorized marketers by the CNMC, acting contrary to the provisions established in the regulations on personal data protection, irrespective of the sector regulations.

The AEPD has stated regarding the nature of the SIPS electrical data that “the Supply Point Information System incorporates personal data, given that from the Supply Point Code it is possible to identify the consumer to whom the information refers, thus linking all the content of the system with that consumer.”

As stated in the Facts, the SIPS is a database of technical, consumption, and commercial data for each of the supply points connected to each electricity or natural gas distributor.

According to Royal Decree 1011/2009, of June 19, which regulates the Supplier Change Office (OCSUM), the information from the SIPS was provided by the OCSUM, once this information was collected from the distributors.

From 01/07/2014, the CNMC assumed the functions of the OCSUM in accordance with the provisions of Transitional Provision 3 of Law 24/2013, of December 26, on the Electricity Sector; among those functions was the delivery of the databases of supply points to the electricity and natural gas marketers that requested them.

Subsequently, the system for delivering/receiving information was adapted to a new procedure that uses an API application on the CNMC website. All this, in order to facilitate access to the electricity and gas SIPS for all registered marketers. Both the structure, access conditions, confidentiality of the data, etc., of the SIPS are regulated in the corresponding regulations of the electricity sector.

According to Article 6.1.f) of Law 24/2013, of December 26, on the Electricity Sector:

“f) The marketers, which are those commercial companies or consumer and user cooperative societies that, accessing the transport or distribution networks, acquire energy for sale to consumers, to other subjects of the system, or to carry out international exchange operations under the terms established in this law.

Regulations will establish the procedure and requirements to be a reference marketer.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

53/81

Now, for the exercise of the marketing activity, the interested parties must communicate the start of activity specifying the territorial scope in which the activity will be developed, to the General Directorate of Energy Policy and Mines of the Ministry of Energy, Tourism and Digital Agenda.

This communication must be submitted accompanied by a responsible declaration regarding compliance with the requirements for the exercise of the activity.

The General Directorate of Energy Policy and Mines forwards the communication made by the interested party to the CNMC, which publishes it on its website and maintains an updated list at least monthly, including all marketers.

In the event that a marketer fails to comply with any of the requirements necessary for the exercise of its activity, the Ministry for Ecological Transition and the Demographic Challenge may initiate a disqualification procedure that ends with the extinction of the authorization to act as a marketer, which is communicated to the CNMC.

Furthermore, the obligations that marketers must comply with regarding the confidentiality of information related to supply points are indicated. According to current regulations, SIPS data is confidential.

For consultation or download of SIPS information, marketers must first request registration in the management system of the electricity and gas supply point databases from the CNMC, through the procedure established for this purpose. This request must be analyzed and validated by the CNMC before access is granted.

The registration request must be made by a legal representative of the marketer, who expressly

guarantees that they will comply with the applicable regulations on personal data protection regarding the received data, and that they will maintain confidentiality of the information at all times, adopting the necessary and appropriate measures in the processing processes, which are their sole responsibility. Access to the SIPS information from the CNMC is only allowed to energy marketers that are registered in the list of marketers available on the CNMC website through an application programming interface (API).

Article 43.1.k) of Law 24/2013, of December 26, on the Electricity Sector establishes that it is the obligation of marketing companies:

“(…)

k) To preserve the confidentiality of the information they become aware of in the performance of their activity, when its disclosure may lead to commercial problems, without prejudice to the obligation to inform Public Administrations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

54/81

(…)”.

Article 7.3 of Royal Decree 1435/2002, of December 27, which regulates the basic conditions for contracts for the acquisition of energy and access to low voltage networks, establishes that:

“(…)”

3. Both the National Commission of Markets and Competition and the marketers that have submitted the notification of the start of activity and responsible declaration, appear on the list published by the National Commission of Markets and Competition and comply at all times with the requirements necessary to carry out the activity, may access the databases of supply points of each distribution company free of charge.

(…)”

The marketers, and other parties that make use of the information contained in the databases of supply points of the distribution companies, in accordance with the provisions of this provision and Article 46.1.k) of Law 24/2013, of December 26, on the Electricity Sector, must subscribe to a code of conduct and guarantee the confidentiality of the information contained therein.

Well, from the documentation in the file and the statements made both by the CNMV and by the respondent in response to the information requests of this Agency prior to the opening of the agreement to initiate the present sanctioning procedure, as well as what was alleged subsequently during the procedure, a series of behaviors affecting the right to the protection of personal data are evidenced and accredited.

The respondent, in its capacity as data processor, may adopt organizational and operational decisions that are necessary for the provision of the service contracted, but under no circumstances may it change the purposes and use of the data nor may it use them for its own purposes, since if it did so, it would become the data controller.

On the other hand, if the respondent, in its capacity as data processor, establishes relationships in its own name and without it being noted that it acts on behalf of another, it will not be considered a data processor but rather a data controller, even if there is a contract or legal act of data processing assignment.

Thus, Article 33.2 of the LOPDGDD establishes that:

“(…)”

2. A person will be considered a data controller and not a data processor who, in their own name and without it being noted that they act on behalf of another, establishes relationships with the affected parties even if there is a contract or legal act with the content set forth in Article 28.3 of Regulation (EU) 2016/679. This provision shall not apply to data processing assignments made within the framework of public sector contracting legislation.

A person will also be considered a data controller who, while appearing as a data processor, uses the data for their own purposes.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
55/81
(...)"

The respondent, based on the service provision contract formalized with the marketer NCE, whose credentials were used for downloading the SIPS databases through the CNMC API, has facilitated a business model with a group of electricity marketers, both authorized and unauthorized for access to SIPS data, and even those in a situation of being inactive to operate as marketers, for their own benefit without it being recorded that they acted on behalf of another and outside the contract signed with NCE.

In the present case, it is evident that the respondent has violated the principle of lawfulness contemplated in Article 6.1 of the GDPR derived from two distinct treatments: the downloading of data from the SIPS without having the authorization of the CNMC and, secondly, facilitating and enabling access to SIPS data by energy marketers, both authorized and unauthorized for access to the SIPS, without it being accredited that they had any of the legitimizing bases of the aforementioned provision.

1. Regarding the first of the mentioned treatments, it is specified in the processing of the data derived from the downloading of the SIPS databases through the CNMC API, for which they were not specifically authorized.

It should be noted that the service provision contract signed with the marketer NCE, in its clause 1, Object, establishes that "The object of this agreement is the regulation between the Data Controller and the Data Processor, for the purpose of complying with the provisions of Article 28 of the General Data Protection Regulation (hereinafter GDPR)."

In its clause 2, Assignment, it is established that "The delivery of data by the Data Controller to the Data Processor does not have the legal consideration of communication or transfer of data, but rather of simple access to the same as a necessary element for the execution of the contractually established services.

Such data will be strictly necessary for the fulfillment of the contractually established services, and copies of these may not be made, nor may they be transferred to another computing environment, nor may they be assigned or delivered to third parties, under any title, not even for mere conservation purposes, except as indicated regarding the possibilities of subcontracting.

In the event that the Data Processor, including its employees or third parties contracted by it in any way, allocates the data to another purpose, communicates it, or uses it in violation of the instructions given by the Data Controller, the stipulations of the agreement, or the current legislation at any given time, they will also be considered responsible for the processing, being liable for the infringements in which they may have personally incurred."

It is recorded that the respondent has developed an application called Kommodo SIPS for electricity marketers, intended for the storage, processing, and consultation of databases of electricity supply points.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
56/81

Interested marketers in its use must enter into a service provision contract with the respondent, provided they are duly accredited before the CNMC. As the respondent itself points out, although the contract contemplates the possibility of offering data related to gas, Kommodo SIPS has never supported this functionality and therefore only offers information on electricity.

As an Annex to the contract, a Data Processing Agreement is included, specifying that the marketer acts as the data controller and designates the respondent as the data processor.

The contract is referred to as a contract for the provision of the basic, free version of technological services for the storage, processing, and consultation of databases of gas and electricity supply points

(SIPS).

However, contrary to what was agreed in the contract signed with the marketer NCE, the respondent periodically and on a monthly basis carried out the download through the CNMC API of a complete copy of the information on consumption and electricity supply points. This downloaded information was processed, eliminating the previous copy. Such downloads were carried out using the certificate (key and secret) of a single marketer, NCE, with which the respondent had formalized the corresponding service contract.

The processed information, stored locally, was offered through the application to the marketers who were clients of the respondent, filtering and searching for information in an agile manner for each of the downloaded supply points.

Additionally, the application provided the possibility to consult monthly consumption and a suggestion for power optimization calculated by the system based on historical consumption, obtained from the latest readings downloaded from the CNMC, and not accessing historical copies, as these were deleted.

Access to Kommodo SIPS was permitted through a username and password to users designated by the marketers with whom the corresponding service provision contract had been signed.

However, access to the CNMC's SIPS information is allowed for those energy marketers that are registered in the list of marketers available on the CNMC's website and, furthermore, requires that one or more representatives of these marketers have been authorized by the aforementioned body in the management system of the databases of electricity and gas supply points, through the procedure established for this purpose.

The CNMC, on its website and in the response provided on 13/02/2023, to the request made by the acting inspector, indicated that access to SIPS information is permitted for energy marketers that are registered in the list of marketers and, additionally, it is necessary for this body to grant a specific and nominative authorization to one or more.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
57/81

representatives of the marketer in the management system of the databases of electricity and gas supply points, through the procedure established for this purpose, who will expressly guarantee that they will comply with the applicable regulations regarding the protection of personal data concerning the data received, and that they will maintain the confidentiality of the information at all times, adopting the necessary and precise measures in the processing processes, which are their exclusive responsibility.

Furthermore, it was stated that the information from the SIPS cannot be used for purposes other than those of energy marketing, and it is not possible to use the SIPS for other uses.

Therefore, it was indicated that it was not possible to market the data from the SIPS as it is a database owned by the CNMC, and only this body can provide access to the information contained therein.

In the case examined, as stated in the proven facts and mentioned earlier, a complete copy of the information on consumption and electricity supply points was periodically downloaded on a monthly basis, and once downloaded, it was processed by deleting the previous copy; the download was carried out according to its own statements using the certificate of the marketer NCE.

The marketer NCE itself has stated that, once the service provision contract with the respondent was signed, it obtained access as a user to the CNMC API to carry out the tasks of reading information, adapting the training, processing data, and presenting it.

However, when requested from the marketer NCE the application form for registration of the marketer in the management system of databases of supply points (SIPS V2) for gas and electricity, it provided the same along with its registration proof, dated 12/09/2016, but it lists as the legal representative and authorized for the purpose of the request and receipt of the SIPS databases Mr. D. B.B.B., joint administrator of the marketer, who commits:

“1.- That the APPLICANT on behalf and representation of the requesting entity requests registration in

the management system of the Databases of Electricity and Gas Supply Points.

II.- That the National Commission of Markets and Competition, in the exercise of the powers attributed to it under Law 24/2013, of December 26, on the Electricity Sector and Article 3.s) of Royal Decree 1011/2009, of June 19, which regulates the Supplier Change Office, will grant free of charge to the REQUESTER, under Article 11.2.a) of Organic Law 15/1999, of December 13, on the Protection of Personal Data, through secure telematic procedures, the information related to the Databases of Electricity and Gas Supply Points concerning the geographical area established in the electricity and gas supply licenses of the REQUESTER.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
58/81

III.- The National Commission on Markets and Competition expressly warns the PETITIONER that it is obliged to comply with Organic Law 15/1999, of December 13, on the protection of personal data and Royal Decree 1720/2007, of December 21, which approves the Regulation for the development of the aforementioned Law, and must process the data in accordance with the applicable regulations regarding the transfer made, and not apply or use it for a purpose other than that which justifies its transfer, without the possibility of communicating it, even for its conservation, to other persons, being all of this solely and exclusively their responsibility from the moment of the delivery made.

IV.- The APPLICANT, on behalf and representation of the PETITIONER, expressly guarantees that it will comply with the applicable regulations on the protection of personal data regarding the data received and that it will maintain at all times the confidentiality of the information of the data it has received, adopting, for this purpose, the necessary and appropriate measures in the processing processes, which are of its exclusive responsibility. In particular, the APPLICANT, on behalf and representation of the PETITIONER, commits to inform the personnel who use the information of its confidential nature and its subjection to the regulations on the protection of personal data, as well as to immediately put in place the necessary means to ensure respect for such conditions.

However, there is no appointment of any other representative of the marketer specifically authorized to carry out the aforementioned download, and when requested, the appointment of the representative of the respondent who would be authorized to download the supply point databases, the marketer stated in a letter dated 10/16/2023 that “since the service provision contract with Tecnología Sistemas y Aplicaciones S.L. is from 2015, that is, almost eight years ago, the request for a change of manager of the SIPS has not been found,” which is paradoxical.

It is also paradoxical and surprising what the aforementioned marketer stated to the CNMC in a letter dated 03/22/2022 when it states, and this is recorded in the proven facts, that “EUROPEAN STRATEGIC MANAGEMENT GROUP S.L.U. (A2U) is currently the CRM service provider for NCE. Access by NCE's sales representatives to CUPS data is done exclusively from that application” and that the company ASIC XXI, which shares its activity with NCE, uses its credentials to access the SIPS databases, which would support what the CNMC indicated in its letter regarding the unusual number of queries and downloads made from the electric SIPS.

That is to say, NCE, despite having a contract with the respondent, uses another company as a CRM service provider and, furthermore, the company ASIC XXI, with which it shares activity, uses, like the respondent, its credentials and access codes to the SIPS when the only legal representative for these purposes is its joint administrator.

The respondent also refers to this when in a letter dated 04/26/2023 it states that the marketer NCE, responsible for the processing, has its own software for querying the SIPS and makes its own requests, having nothing to do with the activity carried out by the marketer.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
59/81

Therefore, in light of the above, the respondent did not have specific authorization for the download of the SIPS databases for its own purposes, which constitutes a violation of what is established in Article 6.1 of the GDPR, since the processing carried out reveals the absence of a legal basis that legitimizes it.

2. Regarding the second of the treatments contrary to the regulations on data protection for which the respondent had no legal legitimacy, it is manifested in the delivery and access to the SIPS data by authorized and unauthorized marketing companies by the CNMC for access to the SIPS.

As previously indicated, the respondent is not an energy marketer and is also not authorized for access to the SIPS; according to the information published on its website, it is a company specialized in the development of software solutions for the energy sector; in this regard, it has developed an application aimed at gas and electricity marketers, intended for the storage, processing, and consultation of the SIPS databases.

The investigated party and NCE signed a contract for the provision of the basic, free version of technological services for the storage, processing, and consultation of gas and electricity supply point databases.

Its purpose is the electronic provision, remotely and on the servers of the latter or those of third parties, of the service of storage, processing, and consultation of the database(s) of gas and electricity supply points ("SIPS"), through the software application for gas and electricity marketers, in its basic version called "KOMMODO SIPS" ("the Service").

Its functional scope is "the storage, processing, and consultation of the SIPS database, with the system initially prepared to load information from the gas or electricity distribution companies available through the CNMC API."

And in clause five, the technical conditions for access and provision of the service are contained, stating that "For the USER (CNE) to access the provision of the Service, it authorizes the PROVIDER (investigated party) of the Service to access the SIPS database through the CNMC API on behalf of the USER, based on the express authorization that the USER states to have from the gas and/or electricity distributors.

The PROVIDER will access the SIPS database through the CNMC API on behalf of the USER, and may not use the data for any purpose other than that stated in this Contract."

In the Annex to the contract, there is an agreement on the protection of personal data whose purpose is to comply with the provisions of Article 28 of the GDPR; regarding the assignment: the delivery of data from the data controller to the data processor does not constitute communication or transfer of data and that these will be strictly necessary for the fulfillment of the contractually established services, and copies of these may not be made, nor may they be transferred to another IT environment, nor may they be assigned or delivered to third parties, under any title except as indicated concerning the possibilities of subcontracting.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

60/81

Therefore, the download of the SIPS databases from the CNMC was carried out by the respondent using the credentials granted by the CNMC to NCE, which authorized the latter to perform the corresponding queries and downloads.

In response to the CNMC, the respondent stated that "Specifically, the certificate (key and secret) of NCE is being used... for obtaining information from the CNMC API. Just like with all accredited marketers accessing Kommodo SIPS, there is a service provision contract between Tecsisa and NCE."

Once the databases were downloaded, the information contained therein was offered to the marketers with whom the respondent had signed the corresponding service provision contract, allowing them to perform searches and queries of the obtained information, initially at no cost, although according to the respondent's own statement, to incentivize future contracting of more advanced versions and other

software applications.

Therefore, the contracting marketers, as stated by FORTIA (one of the contracting marketers), had access to the SIPS databases, which had previously been downloaded with NCE's code, through the respondent's software and by virtue of a contract of the same nature signed with each of them.

That is to say, the SIPS data was not downloaded by the marketers through the code or credentials granted by the CNMC to each of them, but it was the respondent who, once the downloads were made with the credentials granted to CNE, made them available to them, enabling access to marketers who were not even authorized by the CNMC and even in a situation of deregistration, marketing with the SIPS data.

It should not be forgotten that the respondent offered the application "Kommodo Sips" through its website stating: "Consult the data of your future clients from a single system. Access to SIPS with all the aggregated data from the main distributors."

And on those same pages, the logos of marketers who supposedly used the application appeared as a claim with the indication "Marketers who already trust Kommodo."

The acting inspector in his report indicated that he had accessed the website verifying the logos published in the section "Our Clients" and that in addition to the logos of the business groups "Acciona," "Enel," and "Sacyr," logos of another 30 client entities of Kommodo SIPS were observed, all present in the list of client entities provided to the CNMC.

3. It should be noted that the CNMC has attached a list of entities that used the Kommodo SIPS application extracted from the respondent's website, of which 32 companies did have authorization to access the SIPS; 21 companies were not authorized to access the SIPS, and 2 companies were in a "deregistration" situation.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

61/81

The respondent also communicated a list of entities that had been removed from the system; of the total 75 companies listed in the document dated 22/03/2022, only 30 continued to have access to the Kommodo SIPS system. Of these 30 entities, 26 were active in the list of electricity marketers published by the CNMC; the remaining four: Viva Luz Soluciones, S.L. which was removed on 18/03/2022, were not authorized to access the SIPS; Iberoelectrica 3000, S.L. which was removed on 22/03/2022; Fusiona Comercializadora, S.A. which was removed on 20/04/2022; and Comercial Suministros Electricos y Gas, S.L. which was removed on 21/04/2022.

Furthermore, among these 30 entities, there were six others that have been classified as unauthorized to access the SIPS by the CNMC, information that has been confirmed in evidence: Nosa Enerxia, S.C.G, Solabaria, Megara Enercia S.Coop., Petronavarra, S.L., DX Comercializadora Energética, and Novaluz Energía.

It follows that the investigated party has violated Article 6.1 of the GDPR by processing data without any legal basis, by enabling access to SIPS data, through its software application, to both authorized and unauthorized marketers by the CNMV, and even those in a status of removal.

In conclusion, having acted in its own name and without any indication that it was acting on behalf of another, the respondent is considered responsible for the processing carried out contrary to the provisions of Article 6.1 of the GDPR as it had no legal basis for doing so.

VI

Obligation breached. Article 25

1. The respondent is attributed with the infringement of Article 25, "Data protection by design and by default," of the GDPR which establishes:

"1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity that the processing poses to the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively

apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects.

2. The data controller shall implement appropriate technical and organizational measures to ensure that, by default, only personal data that are necessary for each specific purpose of the processing are processed. This obligation shall apply to the amount of personal data collected, the extent of their processing, the duration of their storage, and their accessibility. Such measures shall ensure in particular that, by default, personal data are not accessible, without the intervention of the data subject, to an indeterminate number of natural persons.

3. An approved certification mechanism in accordance with Article 42 may be used as an element to demonstrate compliance with the obligations laid down in paragraphs 1 and 2 of this Article.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

62/81

This article falls within the general obligations that Chapter IV of the GDPR establishes for the data controller, imposing a design obligation at the moment of determining the means of processing, which must effectively ensure compliance with the principles of data protection. The GDPR requires data controllers to establish the necessary technical and organizational measures throughout the entire lifecycle of processing, both from the initial moment when the processing is defined and the means are determined, as well as during its implementation and regular operation.

Data protection by design aims to apply the principles of data protection in the design processes of the systems and procedures of the organization on which the data processing relies, with a predominantly preventive purpose aimed at avoiding potential harm to individuals and, collaterally, the detriment that modifications or redesigns of the systems in which the processing takes place could entail for the organization once developed and implemented, as a consequence of identifying design flaws that could cause harm or detriment to the data subjects and their rights and freedoms.

In line with these provisions, Recital 78 of the GDPR states:

The protection of the rights and freedoms of natural persons with regard to the processing of personal data requires the adoption of appropriate technical and organizational measures to ensure compliance with the requirements of this Regulation. In order to demonstrate compliance with this Regulation, the data controller must adopt internal policies and implement measures that particularly comply with the principles of data protection by design and by default. Such measures could consist, among others, of minimizing the processing of personal data, pseudonymizing personal data as soon as possible, providing transparency regarding the functions and processing of personal data, allowing data subjects to monitor the processing of data, and enabling the data controller to create and improve security elements. When developing, designing, selecting, and using applications, services, and products that are based on the processing of personal data or that process personal data to fulfill their function, producers of products, services, and applications should be encouraged to take into account the right to data protection when developing and designing these products, services, and applications, and to ensure, with due regard to the state of the art, that data controllers and processors are in a position to fulfill their obligations regarding data protection. The principles of data protection by design and by default should also be considered in the context of public contracts.

Specifically, in light of Recital 78 of the GDPR, the principle of data protection by design is the key for the data controller to demonstrate compliance with the GDPR, as "the data controller must adopt internal policies and implement measures that particularly comply with the principles of data protection by design and by default."

The principle of privacy by design is a demonstration of the shift from reactivity to proactivity and a direct manifestation of the risk-based approach imposed by the GDPR. Part of the proactive responsibility requires that this principle be considered from the earliest stages of planning a processing operation: the data controller must take this into account from the moment it is designed and...

When planning any potential processing of personal data, all elements that constitute the processing must be determined in order to effectively apply the principles of data protection, integrating the necessary guarantees in the processing with the ultimate aim of protecting the rights of the data subjects, in compliance with the provisions of the GDPR.

Thus, regarding the risks that may be present in the processing, the data controller shall carry out an analysis and detection of risks throughout the entire data processing cycle, with the primary and ultimate purpose of protecting the rights and freedoms of the data subjects, and not only when the processing actually occurs. This is expressed in the Guidelines 4/2019 of the EDPB concerning Article 25 Data Protection by Design and by Default adopted on October 20, 2020.

In the aforementioned Guidelines, it is stated that:

“35. The ‘moment of determining the means of processing’ refers to the period during which the controller is deciding how to carry out the processing and how it will occur, as well as the mechanisms that will be used to carry out such processing. In the process of making such decisions, the data controller must evaluate the appropriate measures and guarantees to effectively apply the principles and rights of the data subjects in the processing, and take into account elements such as risks, the state of the art, and the cost of implementation, as well as the nature, scope, context, and purposes. This includes the moment of acquiring and implementing the software and hardware and the data processing services.

36. Considering Data Protection by Design and by Default from the outset is crucial for the correct application of the principles and for the protection of the rights of the data subjects. Furthermore, from a cost-effectiveness perspective, it is also in the interest of data controllers to take Data Protection by Design and by Default into consideration as early as possible, as it may later become difficult and costly to introduce changes to already formulated plans and designed processing operations.”

To this end, when designing the processing, the principles set out in Article 5 of the GDPR must be applied, which will serve to gauge the effective compliance with the GDPR. Thus, the aforementioned Guidelines 4/2019 of the EDPB state that “61. To make Data Protection by Design and by Default effective, data controllers must apply the principles of transparency, lawfulness, fairness, purpose limitation, data minimization, accuracy, storage limitation, integrity and confidentiality, and proactive responsibility. These principles are set out in Article 5 and Recital 39 of the GDPR.”

The Privacy by Design Guide from the AEPD states that “Privacy by Design (hereinafter, PbD) involves using a risk management and proactive responsibility approach to establish strategies that incorporate privacy protection throughout the entire lifecycle of the object (whether it is a system, a hardware or software product, a service, or a process). The lifecycle of the object refers to all the stages it goes through, from its conception to its withdrawal, including the phases of development, production, operation, maintenance, and withdrawal.”

The Guide states that “Privacy must be an integral and inseparable part of systems, applications, products, and services, as well as of the business practices and processes of the organization. It is not an additional layer or module that is added to...”

pre-existing, but must be integrated into the set of non-functional requirements from the very moment it is conceived and designed (...) Privacy is born in the design, before the system is operational, and must be guaranteed throughout the entire data lifecycle.”

Therefore, privacy by design, an obligation of the data controller that arises before the system is operational, is not a patch that is applied to a system built with disregard for the GDPR.

2. In this regard, concerning the infringement of Article 25 of the GDPR, it should be noted that the principle of data protection by design has not been taken into account.

From the documentation provided by the respondent during the investigation phase of this procedure, it is evident that there has been a failure to comply with the obligation imposed by Article 25 of the GDPR, and the measures established by the respondent cannot be considered as fulfilling the provisions of that article, which calls for the protection of the rights and freedoms of citizens in the processing of their data, not merely the formal imposition of obligations on other parties.

As stated in the initiation agreement, any marketer, whether or not they had authorized access to the SIPS by the CNMC, could be a user of the respondent, as inferred from the previous grounds.

Firstly, the system designed by the respondent allows any marketer access to the data downloaded from the SIPS, through the use of the Kommodo SIPS application, circumventing the security measures related to user identification and authentication implemented by the regulator, the CNMC, without the need for users to have passwords or access codes for downloading the distributors' databases via the CNMC API.

Clause Five, Technical Conditions for Access and Provision of the Service, of the contract signed with the marketers states: "In order for the USER to access the provision of the Service, it authorizes the SERVICE PROVIDER to access the SIPS database through the CNMC API on behalf of the USER, based on the express authorization that the USER claims to have from the gas and/or electricity distributors.

The SERVICE PROVIDER will access the SIPS database through the CNMC API on behalf of the USER, and may not use the data for any purpose other than that stated in this Contract."

However, despite this provision, the reality showed that marketers, both those with authorization for downloading and consulting the SIPS and those without such authorization, could access the databases through the Kommodo SIPS application, previously downloaded with the code of the CNE marketer, with no evidence or proof that these entities had accessed the information contained in those databases as a result of access to them, whether by download or consultation, through the code or credential granted by the CNMC.

It is the respondent itself who, in response to the question posed during the evidence phase regarding whether downloads from the SIPS had been carried out with codes from other...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

65/81

Commercializers, responded that "The answer to this question is no. At no time has TECSISA downloaded the SIPS with codes from other electricity commercializing entities."

And that "TECSISA puts into production for the electricity commercializing entities the application that offers SIPS data downloaded through the CNMC API as of September 26, 2018.

Therefore, in response to the question raised, the download of the SIPS through the CNMC API with the agent code of Nueva Comercializadora Española S.L. is carried out from the cited date, September 26, 2018, in the production environment of the Kommodo SIPS software."

Furthermore, it is possible that there were commercializers who, having been authorized to operate in this regard and having ceased to be authorized, continued to have access to the SIPS data, as deduced from the statements of the investigated party.

It is true that regarding the deregistrations it is indicated that "To proceed with the registration of a commercializer in Kommodo SIPS, it must meet the access requirements stipulated by law. For this, Tecsisa requests the commercializer:

- SIMEL code of participant in the Electricity Market.
- AGENT code assigned by the CNMC.
- CIE code (Electricity Identification Code) assigned by AEAT.

Additionally, Tecsisa manually verifies the presence of the company (by corporate name and CIF) in the List of Electricity Commercializers published by the CNMC on the website

<https://sede.cnmc.gob.es/listado/censo/2> and that its geographical scope of action is at least

"Peninsular."

Once these checks are carried out and the service provision contract is signed, the respondent proceeds to register the users designated by the commercializer in the Kommodo SIPS application." But it is also noted that "it has an internal procedure by which, periodically, it manually reviews the list of electricity marketers published by the CNMC (**URL.5) and when it detects that a company has been deregistered from that list, it proceeds to eliminate access and notify that company by email," that is, it is certifying that the aforementioned measures were so inappropriate and inadequate that it was necessary to resort to a manual procedure to reliably check the deregistrations by consulting the list published by the CNMC, which supports the suspicion, proven by the statements of the CNMC, that there were commercializers in a deregistered situation accessing the SIPS data.

The risk approach refers directly and immediately to a preventive system aimed at visualizing, regarding the processing of personal data, the risks to the rights and freedoms of individuals. Therefore, other series of risks to which the organization may be subjected and that affect its business scope must be excluded from the data protection risk approach.

In relation to the risks to the rights and freedoms of individuals, the risks must be identified, their impact evaluated, and the probability that

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

66/81

those are materialized. Thus, it is not the data that is protected, but rather the individuals behind it.

The risks to the rights and freedoms of natural persons arising from the processing of personal data can vary in severity and likelihood, potentially causing physical, material, or immaterial harm, as well as tangible or intangible consequences for the rights and freedoms of natural persons. Recital 75 of the GDPR and Article 28.2 of the LOPDGDD exemplify some of the risks considered by the legislator, but they are not the only ones. It will depend on the processing and the context in which it occurs, the personal data processed, the individuals involved, the means used, etc.

In this case, the respondent evaded the procedure implemented by the CNMC, preventing the body with the authority to establish the processes for the exchange of information between distributors and marketers and responsible for the processes of changing marketers from verifying the accesses made by marketers to the SIPS, which poses a risk to the rights and freedoms of the data subjects by evading the control that the CNMC exercised over access to personal data.

3. It should also be noted that Guidelines 4/2019 regarding Article 25 indicate that measures must be adopted to effectively apply the principles, which implies that the data controllers must implement the necessary measures and adopt guarantees to respect these principles, in order to ensure the rights of the data subjects. However, in the analyzed case, such measures were not adopted to ensure the principle of lawfulness.

The documents provided neither contained nor arbitrated technical or organizational measures that could prevent the infringement of the fundamental right to data protection, and along with it, the rights and freedoms of the users whose data are included in the SIPS.

In this regard, it should be recalled that according to Article 25 of the GDPR:

"Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and integrate the necessary guarantees in the processing, in order to comply with the requirements of this Regulation and protect the rights of the data subjects."

That is to say, the protection of the fundamental right to data protection does not consist of a mere "reactive" waiting for a problem that may infringe it to occur, but rather that the data controllers must design ("data protection by design") appropriate policies for the protection of this fundamental right

prior to the commencement of processing. This includes all aspects regulated in the GDPR, starting with the obligations of transparency, respect for the exercise of the rights established in the Regulation, and the establishment of all necessary technical and organizational measures to ensure compliance with the Regulation.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
67/81

that standard. And all of this must be planned and implemented prior to the commencement of processing by the controller.

As a result of the inspection actions carried out by this Agency, as well as the other documentation and allegations presented by the respondent in this procedure, it has been confirmed that this principle (and consequently Article 25 of the GDPR) was not complied with by the respondent. There was no procedure or measures in place to comply with the GDPR.

In this regard, it should be noted that the risk analysis is a key component of the principle of privacy by design, as it allows for the establishment of technical and organizational measures to prevent them or, in the event they occur, to mitigate them. However, in this case, the respondent did not conduct an analysis of the risks that the processing of the data it had established posed to the rights and freedoms of the data subjects, which consisted of accessing the SIPS through the credentials of a single marketer and making it available to other marketers for which the CNMC had no record of them having access to personal data.

As noted, Article 25 makes special reference to "the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons," as a prerequisite for the establishment of such measures.

In light of these facts, it is considered that the respondent entity, through its actions, violates Article 25 of the GDPR, which regulates data protection by design and by default, where the data controller is required to apply, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures designed to effectively apply the principles of data protection and integrate the necessary safeguards into the processing, in order to comply with the requirements of the GDPR and protect the rights of the data subjects.

The described facts would constitute a violation of the provisions of Article 25 of the GDPR.

VII

Conclusion

It has already been stated that the data contained in the SIPS are personal data, which were downloaded through the CNMC API, with downloads occurring monthly, allowing access and consultation of this information by marketers, both authorized and unauthorized by the CNMC, without any legal basis.

The GDPR establishes the need to document and clearly identify the legal basis on which the processing of personal data of the data subjects is carried out, which has not been evidenced by the respondent. It also establishes and indicates that the measures aimed at ensuring compliance must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of individuals.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
68/81

In the present case, the respondent was not authorized to process the personal data contained in the SIPS databases, nor to transfer the same to third parties, and did not have guaranteed protection by design, posing a risk to the rights and freedoms of individuals. It should not be forgotten that we are dealing with a fundamental right, and, as has already been pointed out, it does not consist of a mere "reactive" waiting for an incident that may harm them; on the contrary, its violation can acquire

systemic connotations and, therefore, affect individuals even if they have not filed complaints with the supervisory authority.

In light of this, based on the available evidence, it is concluded that:

The respondent has committed two violations of Article 6.1 of the GDPR, as the entity accessed the SIPS database through the CNMC API with the purpose of offering it to its clients, without having any legitimacy, proceeding to download it through an automated process, obtaining a complete copy of the information on electricity consumption and supply points, and, secondly, the information obtained was made available to accredited and non-accredited marketers before the CNMC for their access to the SIPS, users of Kommodo SIPS, and, through this instrument/application, allowed access to the information contained in the databases.

Therefore, the investigated party has acted in violation of the principle of legitimacy set forth in Article 6.1 of the GDPR, as a consequence of the processing activities mentioned in the preceding paragraph, violations contemplated in Article 83.5 a) of the GDPR.

Lastly, the investigated party has violated Article 25, relating to data protection by design and by default, an infringement classified under Article 83.4.a) of the GDPR, due to the lack of adequate measures.

VIII

Classification of the Violations

In relation to the breach of Article 6 of the GDPR, the infringement attributed to the respondent is classified under Article 83.5 a) of the GDPR, which considers that the infringement of "the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9" is subject to penalties, in accordance with paragraph 5 of the aforementioned Article 83 of the Regulation, "with administrative fines of up to €20,000,000 or, in the case of an enterprise, an amount equivalent to a maximum of 4% of the total annual global turnover of the previous financial year, opting for the higher amount."

The LOPDGDD in its Article 71, Violations, states that: "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute violations."

And in its Article 72, it considers for the purposes of prescription that they are: "Very serious violations: 1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following are considered very serious and will prescribe in three years:

(...)

b) The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679."

(...)

The violation of Article 25 of the GDPR constitutes the commission of the infringement classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides that:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to €10,000,000 or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43;

(...)"

For the purposes of the limitation period, Article 73 "Violations considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and will prescribe in two years:

(...)

d) The failure to adopt those technical and organizational measures that are appropriate to effectively apply the principles of data protection by design, as well as the failure to integrate the necessary safeguards in the processing, in the terms required by Article 25 of Regulation (EU) 2016/679."

(...)

IX

Criteria for Graduating the Amount

Article 58 of the GDPR, Powers, states:

"2. Each supervisory authority shall have all of the following corrective powers indicated below:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

70/81

(...)

i) impose an administrative fine in accordance with Article 83, in addition to or instead of the measures mentioned in this paragraph, depending on the circumstances of each particular case;

(...)"

In order to establish the administrative fine that should be imposed, the provisions contained in Articles 83.1 and 83.2 of the GDPR must be observed, which state:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of data subjects affected and the level of damage and harm they have suffered;
- b) the intentionality or negligence in the infringement;
- c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;
- d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented pursuant to Articles 25 and 32;
- e) any previous infringements committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, compliance with those measures;
- j) adherence to codes of conduct under Article 40 or to approved certification mechanisms under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement."

In relation to letter k) of Article 83.2 of the GDPR, the LOPDGDD, in its Article 76, "Sanctions and corrective measures," establishes that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

71/81

"2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.

- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

According to the transcribed provisions and in relation to the analyzed conduct, the following circumstances that affect the responsibility that can be demanded from the respondent are noted, although in their allegations to the Proposal for Resolution, they consider that none of the indicated circumstances apply to the conduct they displayed.

1. Related to the infringement of Article 6.1 of the GDPR, as a consequence of access to the SIPS database:

As aggravating circumstances:

- The nature and severity of the infringement: the facts revealed seriously affect a basic principle in the field of personal data protection, such as the principle of legitimacy, which is sanctioned with special severity by the GDPR, whose violation is classified as very serious.

Regarding the severity of the infringement, the respondent downloaded data from the SIPS without being authorized by the CNMC, using the credential or code granted by that body to the marketer NCE, with the legal representative authorized for both the request and the receipt of the SIPS databases being the joint administrator of the aforementioned marketer.

The scope of the processing carried out extends to the national, peninsular level, which shows that the processing entails a greater risk and greater difficulty in curbing such conduct, to which should be added the volume of the processing carried out.

The investigated party states in relation to the geographical scope that “a marketer that does not have a scope of action at least at the peninsular level (P) will not have access to Kommodo SIPS, ...”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

72/81

Regarding the volume of treatments carried out. It should be noted that the downloads from the SIPS were conducted monthly using a code for which the entity was not authorized. On the other hand, the investigative actions carried out emphasize and highlight the processing of the data included in the electrical SIPS, observing, in the opinion of the CNMC, an unusual volume in the number of such data, revealing a level of access considered abnormal and unusual; it is sufficient to note that the CNMC in the “Agreement for the referral to the Spanish Data Protection Agency of the actions taken regarding possible fraudulent uses of the SIPS” already cites NCE (one of the marketers potentially involved in the fraudulent use of the SIPS that had a service contract with the respondent), with the following being of interest: “...There are indications of a possible use not in accordance with the purpose of the SIPS in the analysis of the data obtained from individual queries by authorized marketers through the API, as it presents a very high number of queries, far exceeding the volume of switching operations recorded over a specific period of time, and even the number of supply points that are part of its client portfolio...” (...).

The respondent allowed both the marketers authorized for their download and consultation of the SIPS and those that did not have such authorization to access the databases through the Kommodo SIPS application, previously downloaded with the code of the marketer CNE, without any record that these entities accessed and consulted this information, either by download or consultation through the code or credential granted by the CNMC to each of them.

The respondent used the credentials of said marketer to download the SIPS databases and, taking advantage of the service contract signed with the marketers, offered the contained information to them, which favored an excessive number of treatments that did not conform to normality.

The purpose of the processing was the download, through the CNMC's API, of a complete copy of the information on consumption and supply points, and this information is offered by providing access to the marketers who are users of Kommodo SIPS, both authorized and unauthorized by the CNMV in exchange for a financial consideration and, although connected, distanced from what constitutes the main object of the respondent's activity: programming, consulting, and other activities related to computing.

The level of damages suffered to the extent that the conduct being sanctioned affects a fundamental right such as the protection of personal data. The supervisor itself indicated that through the analysis of the recorded access data and the notices from marketers and users, a set of scenarios had been identified, including that concerning the respondent, which suggested possible fraudulent uses of the SIPS impacting the fundamental right to the protection of personal data.

- The manner in which the supervisory authority became aware of the infringement; the present procedure arises from the document "Agreement for the referral to the C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

73/81

Spanish Agency for Data Protection the actions taken in relation to possible fraudulent uses of the SIPS" approved by the Regulatory Supervision Chamber of the CNMC (article 83.2, h) of the GDPR).

- The intentionality or negligence in the infringement; there is a serious lack of diligence in the actions of the investigated entity since it did not have legitimacy for the processing of the data carried out.

Connected also with the degree of diligence that the data controller is obliged to deploy in compliance with the obligations imposed by data protection regulations, the SAN of 17/10/2007 can be cited.

Although it was issued before the entry into force of the GDPR, its pronouncement is perfectly extrapolable to the case we are analyzing. The ruling, after referring to the fact that entities whose activity involves continuous processing of data from clients and third parties must observe an adequate level of diligence, specified that "(...). the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard" (article 83.2, b) of the GDPR).

And regarding the claim made by the respondent that when applying this aggravating factor, the principle of good faith should be taken into account, it should be noted that the National Court has stated in rulings that "good faith in acting, to justify the absence of fault –as is done in the present case–; it is enough to say that this allegation is negated when there is a specific duty of vigilance derived from the professionalism of the infringer. In this traditional line of reasoning, the STS of March 12, 1975, and March 10, 1978, reject the allegation of good faith when the infringer has duties of vigilance and diligence arising from their professional status."

- The continued nature of the infringement. The CNMC in a letter sent to the Agency has identified a large number of unauthorized entities whose registration date in the Kommodo SIPS system occurred in 2015 (the date on which it began to provide service according to statements from the respondent); as noted in response to the allegations to the Proposal, the respondent has stated that "since October 15, 2015, TECSISA has begun to provide access services to the SIPS through its Kommodo SIPS platform. This service is provided after signing a contract with the interested accredited marketers and downloading the data from the 5 main distributors (IBERDROLA DISTRIBUCION ELECTRICA, S.A., UNION FENOSA DISTRIBUCION, S.A. (Gas Natural), E.ON DISTRIBUCIÓN, S.L., HIDROCANTABRICO DISTRIBUCION ELECTRICA, S.A. and ENDESA DISTRIBUCION ELECTRICA, S.L.). After the download, the data is processed and consolidated to provide the user

marketers access to it from a single application, which also provides filters and other value-added functions.”

Therefore, taking into account what has been stated by the respondent entity in its allegations to the AEPD, its activity declined on 01/10/2022, the date on which it ended the

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

74/81

Provision of service by Kommodo SIPS, that is, after a long period during which personal data processing was carried out for which the respondent was not legitimized. The respondent states that "On September 1, 2022, the accredited marketers with whom a valid contract was maintained, both for the Free and Premium versions (i.e., paid) of Kommodo SIPS, were notified that TECSISA would cease providing the service as of October 1, 2022."

It also included an email dated 01/09/2022 in which it was communicated that as of 01/10/2022, the service of Kommodo SIPS would cease. The mentioned email indicated:

“What happens now? If you had free access to the platform, from that date you will no longer be able to access and consult the information.

In case you had a premium subscription, we will contact you in the coming days to regularize your situation regarding the months of service not provided, in accordance with the terms of the contract.”

(Article 76.2.a) of the LOPDGDD in relation to Article 83.2.k).

- The benefits obtained as a result of the commission of the infringement.

These benefits have existed since the statements and declarations contained in the file refer implicitly and explicitly to them when mentioning the premium or paid service fees; furthermore, the activity of the respondent is motivated by the pursuit of economic benefit, so the fact that this was not obtained in the desired or expected sense cannot serve in any case as a basis for mitigating culpability.

The contract signed with its clients contemplated this possibility since in its Eighth clause, Expansion or reduction of service capacity, section B.2., Price of plans and renewal of these, it establishes that: “TECSISA, for the use of the CLIENTS of the platform 'KOMMODO SIPS', has the right to charge the fees in force at any given time.

The payment method of the aforementioned price by the CLIENT will be by direct debit to the account designated by the CLIENT, at the beginning of the billing period of each of the contracted paid plans. TECSISA may claim from the client the financial expenses incurred due to the returns of receipts issued for the collection of the price of the contracted service; TECSISA may also include a surcharge in future receipts. Such surcharge will be in the concept of financial charges at a 10% weekly interest calculated on the amount of the installment(s) affected by such non-payment or delay” (Article 76.2.c) of the LOPDGDD in relation to Article 83.2.k) of the RGPD).

- The activity of the allegedly infringing entity is linked to the processing of data from both clients and third parties. The investigated entity has as its corporate purpose, published in the BORME, the individualized and general advice and IT support of software programs, as well as technological consulting, so given the nature of its activity and the number of clients it has supported, the processing of personal data of clients as well as third parties is essential, thus the significance of its conduct subject to the C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

75/81

This procedure is undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

- Business volume or activity according to Axexor, in proceedings carried out on 31/01/2023, the investigated party has a turnover in 2021 (last available financial year) of 2,367,559 euros (Article 83.2.k) of the GDPR).

2. Related to the infringement of Article 6.1 of the GDPR, as a consequence of making available to both authorized and unauthorized marketing companies access to the SIPS of the information

obtained from the data downloads of the SIPS of the CNMC.

As aggravating circumstances:

- The nature and severity of the infringement: the facts revealed severely affect a basic principle in the field of personal data protection, such as the principle of legitimacy, which is sanctioned with special severity by the GDPR, the violation of which is classified as very serious.

Regarding the severity of the infringement, there is a list of companies that used the Kommodo SIPS application, some authorized and others unauthorized, which accessed the SIPS data through downloads carried out by the accused with the code granted by the CNMC to the marketing company NCE, which highlights the seriousness of the infringement.

It is noted that "On the website, they indicate a series of logos corresponding to marketers who supposedly use this software under the indication 'Marketers who already trust Kommodo.' Among these marketers, more than twenty are identified without authorized access to the SIPS. An Excel file accompanying this letter includes a list of marketers identified by their logo published on this company's website, indicating whether or not they have authorized access to the SIPS databases."

The scope of the processing carried out extends to the entire national territory, which manifests and highlights the risk and difficulty of curbing such illicit conduct.

The investigated party indicates regarding the geographical scope that "a marketer that does not have at least a peninsular (P) scope of action will not have access to Kommodo SIPS, ..."

Regarding the volume of the processing carried out. The actions refer to the processing of the data included in the electric SIPS; given the number of contracting marketers, the volume of queries to the SIPS seems unusually high; it is sufficient to note that the CNMC in the "Agreement by which the actions carried out in relation to possible fraudulent uses of the SIPS are referred to the Spanish Data Protection Agency" cites NCE (one of the marketers of possible fraudulent use of the SIPS that had a service contract with the investigated party, being of interest the following: "...There are indications of a possible use not in accordance with the purpose of the SIPS in the analysis of the data obtained from C/ Jorge Juan, 6 www.aepd.es 28001 – Madrid sedeagpd.gob.es

76/81

the individual queries of authorized marketers through API, due to presenting a very high number of queries, far exceeding the volume of switching operations recorded in a given period of time, and even the number of supply points that are part of their client portfolio..."

(...)

The purpose of the processing was the download, through the CNMC API, of a copy of the information on consumption and electricity supply points, and this information is provided by granting access to the marketers who are users of Kommodo SIPS, both authorized and unauthorized by the CNMC, in exchange for a financial consideration (premium or paid fee).

The level of damages suffered to the extent that the conduct being sanctioned affects a fundamental right such as the protection of personal data. The supervisor himself indicated that through the analysis of the recorded access data and the notices from marketers and users, a set of scenarios had been identified, among them the one concerning the complaint, which suggested fraudulent use of the SIPS with an impact on the fundamental right to the protection of personal data.

- The manner in which the supervisory authority became aware of the infringement; the present procedure arises from the document "Agreement to refer to the Spanish Agency for Data Protection the actions carried out in relation to possible fraudulent uses of the SIPS" approved by the Regulatory Supervision Chamber of the CNMC and sent to the AEPD for possible fraudulent uses of the data contained in the SIPS (Article 83.2, h) of the GDPR).

- The intentionality or negligence in the infringement; there is a serious lack of diligence in the actions of the investigated entity since it did not have legitimacy for the processing of the data carried out. Also connected with the degree of diligence that the data controller is obliged to exercise in compliance with the obligations imposed by data protection regulations, the SAN of 17/10/2007 can be cited. Although it was issued before the entry into force of the GDPR, its pronouncement is perfectly extrapolable to the case we are analyzing. The ruling, after referring to the fact that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, specified that "(...) the Supreme Court has understood that there is negligence whenever a legal duty

of care is neglected, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard” (Article 83.2, b) of the GDPR).

- The continued nature of the infringement. The CNMC, in a document sent to the Agency, identified a high number of unauthorized entities whose registration date in the Kommodo SIPS system occurred in 2015 (the date on which it began to provide service according to the statements of the respondent), therefore, if we consider what was indicated by the affected entity in its statements to the AEPD, its C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

77/81

activity declined on 01/10/2022, the date on which the service of Kommodo SIPS ceased to be provided, that is, after a long period of more than seven years. The investigated party stated that “On September 1, 2022, the accredited marketers with whom there was an active contract, both for the Free and Premium versions (i.e., paid) of Kommodo SIPS, were notified that TECSISA would cease to provide the service as of October 1, 2022.”

The document also included an email dated 01/09/2022 in which it was communicated that as of 01/10/2022, the service of Kommodo SIPS would no longer be provided. The mentioned email indicated:

“What happens now? If you had free access to the platform, as of that date you will no longer be able to access and consult the information.

In the event that you had a premium subscription, we will contact you in the coming days to regularize your situation regarding the months of service not provided, in accordance with the terms of the contract.” (Article 76.2.a) of the LOPDGDD in relation to Article 83.2.k).

- The benefits obtained as a result of the commission of the infringement.

These benefits are evident as the investigated party explicitly refers to them both in the various statements made through the submitted documents and in the service provision contract signed with the different marketers, especially through the premium rate (paid) for the use of the service (Article 76.2.c) of the LOPDGDD in relation to Article 83.2.k) of the RGPD).

- The activity of the allegedly infringing entity is linked to the processing of data of both clients and third parties. The investigated entity has as its corporate purpose, published in the BORME, the individualized and general advice and IT support of software programs, as well as technological consulting, so given the nature of its activity, the processing of personal data of clients as well as third parties is essential, making the significance of its conduct subject to this procedure undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

- Volume of business or activity: According to the Annex in proceedings carried out on 31/01/2023, the investigated party has a turnover in 2021 (last available fiscal year) of 2,367,559 euros (Article 83.2.k) of the RGPD).

3. Related to the infringement of Article 25 of the RGPD, as a consequence of the lack of data protection by design and by default:

As aggravating circumstances:

- The nature and severity of the infringement: the facts revealed seriously affect a fundamental issue in data protection, which is the design of necessary and adequate technical and organizational measures for processing, and whose violation is classified as serious.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

78/81

Regarding the severity of the infringement, it is noted that the CNMC has provided a list of companies

that use the Kommodo SIPS application; specifically, there are marketers that have authorization to access the SIPS and others that do not. In particular, there are up to 21 unauthorized companies accessing the SIPS, and even entities in a "low" status; nevertheless, the outcome is the same since all of them access the SIPS data, whether or not they are authorized, through the application developed by the investigated party, which reveals a lack of adequate technical and organizational measures from the design stage.

Therefore, what this conduct implies is allowing access to the system by circumventing the security measures related to user identification and authentication implemented by the CNMC, and in no case is it required for users to have passwords for access to the CNMC.

Thus, FORTIA - a marketer using the system states that "Regarding the origin of the data, as previously indicated, the data comes directly from the SIPS of the CNMC..."

In addition to the above, it should be noted, as mentioned in previous grounds, that even marketers that may be authorized could lose their authorization and still continue to have access, as inferred from the statements of the investigated party: "it has an internal procedure whereby, periodically, it manually reviews the list of electricity marketers published by the CNMC ***URL.6, and when it detects that a company has been removed from that list, it proceeds to eliminate access and notify that company by email," and continues that "having verified in the 'CNMC reports' that the recipient no longer operates as an authorized marketer, it proceeds to remove them from the Kommodo SIPS system in compliance with personal data protection regulations."

The scope of the processing carried out extends to the entire national territory, highlighting the risk and greater difficulty in curbing such illicit conduct.

The investigated party indicates in relation to the geographical scope that "a marketer that does not have a scope of action at least in the peninsula (P) will not have access to Kommodo SIPS, ..."

(...)

The system relies on the use of cloud computing technologies, using AWS as the IaaS (Infrastructure as a Service) provider for information storage. This physical storage is located in AWS Data Centers in Ireland, a country that is part of the European Union."

Regarding the volume of the processing carried out, the CNMC in its writing has indicated that an unusual volume was observed in the number of processing activities carried out by the marketers. The level of damages and losses suffered to the extent that the conduct being sanctioned affects a fundamental right such as the protection of personal data. The supervisor itself indicated that through the analysis of the recorded access data and the notices from marketers and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

79/81

users, a set of scenarios had been identified, including the one concerning the investigated party, which suggested possible fraudulent uses of the SIPS with an impact on the fundamental right to the protection of personal data.

- The manner in which the supervisory authority became aware of the infringement; the present procedure arises from the document "Agreement to refer to the Spanish Agency for Data Protection the actions taken in relation to possible fraudulent uses of the SIPS" approved by the Regulatory Supervision Chamber of the CNMC (Article 83.2, h) of the GDPR).

- The intentionality or negligence in the infringement; a serious lack of diligence is observed in the actions of the investigated entity due to the lack of adequate technical and organizational measures. Also connected with the degree of diligence that the data controller is obliged to demonstrate in compliance with the obligations imposed by data protection regulations, the SAN of 17/10/2007 can be cited. Although it was issued before the GDPR came into force, its ruling is perfectly extrapolable to the case we are analyzing. The ruling, after referring to the fact that entities whose activities involve continuous processing of customer and third-party data must observe an adequate level of diligence, specified that "(...). the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. And in

assessing the degree of diligence, the professionalism or lack thereof of the subject must be especially weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard” (Article 83.2, b) of the GDPR).

- The continued nature of the infringement. The CNMC, in a document sent to the Agency, identified a large number of marketing entities, including unauthorized marketers for access to the SIPS, whose registration date in the Kommodo SIPS system occurred from the year 2015; therefore, if we consider what the respondent stated in their submissions to the AEPD, their activity ended on 01/10/2022, the date on which the Kommodo SIPS application ceased to provide the service, that is, after a period of more than seven years. Thus, the investigated party stated that “On September 1, 2022, accredited marketers with whom a valid contract was maintained, both for the Free and Premium versions (i.e., paid) of Kommodo SIPS, were notified that TECSISA would cease to provide the service as of October 1, 2022.”

And they included in the document an email dated 01/09/2022 in which it was communicated that as of 01/10/2022, the service of Kommodo SIPS would no longer be provided. The mentioned email indicated:

“What happens now? If you had free access to the platform, from that date you will no longer be able to access and consult the information.

In case you had a premium subscription, we will contact you in the coming days to regularize your situation regarding the months of service not provided, in accordance with the terms of the contract.” (Article 76.2.a) of the LOPDGDD in relation to Article 83.2.k).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

80/81

- The benefits obtained as a result of the commission of the infringement. These benefits are evident as the investigated party implicitly refers to them when mentioning the premium rate of the service (Article 76.2.c) of the LOPDGDD in relation to Article 83.2.k) of the GDPR).

- The activity of the allegedly infringing entity is linked to the processing of data from both clients and third parties. The investigated entity has as its corporate purpose, published in the BORME, the individualized and general advice and IT support of software programs, as well as technological consulting, therefore, given the nature of its activity, the processing of personal data of clients as well as third parties is essential, making the significance of its conduct subject to this procedure undeniable (Article 76.2.b) of the LOPDGDD in relation to Article 83.2.k).

- Business volume or activity according to Axexor, in proceedings carried out on 31/01/2023, the investigated party has a turnover in 2021 (last available financial year) of 2,367,559 euros (Article 83.2.k) of the GDPR).

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

The Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on TECNOLOGÍA SISTEMAS Y APLICACIONES, S.L., with NIF B83128033:

- For infringement of Article 6.1 of the GDPR, classified under Article 83.5.a) of the GDPR (downloading the SIPS database without having the legitimacy for it), a fine of 45,000 euros (forty-five thousand euros).

- For the infringement of Article 6.1 of the GDPR, classified under Article 83.5.a) of the GDPR (making available to the clients of the respondent, authorized and unauthorized marketing companies for access to the SIPS, the information from the database without having the legitimacy for it), a fine of 45,000 euros (forty-five thousand euros).

- For the infringement of Article 25 of the GDPR, classified under Article 83.4.a) of the GDPR, a fine of 25,000 euros (twenty-five thousand euros).

SECOND: NOTIFY this resolution to Mr. C.C.C., with NIF ***NIF.1.

THIRD: This resolution will be executive once the period for filing the optional appeal for

reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that they must pay the imposed sanction once this resolution becomes executive, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of 17 of

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
81/81

December, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, to the restricted account no. IBAN: ES00 0000 0000 0000 0000 0000 (BIC/SWIFT Code: XXXXXXXXXXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once it is executive, if the date of executive status falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Litigation Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Litigation Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency is not aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

Mar España Martí
Director of the Spanish Agency for Data Protection
C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es